



DESCRIPTION OF PROCESSING

Data & More ApS - ISAE 3000 Type 1 Service Organization
Description

Document Version: 1.0

Effective Date: July 18, 2025

Organization: Data & More ApS

Audit Scope: ISAE 3000 (Revised) - Assurance on Controls at a Service Organization

Audit Period: January 1, 2025 - December 31, 2025



EXECUTIVE SUMMARY.....	4
SECTION 1: SERVICE ORGANIZATION OVERVIEW.....	5
1.1 Organization Structure and History.....	5
1.2 Service Description.....	5
1.3 Data Processing Activities.....	5
1.4 Regulatory Environment.....	6
SECTION 2: CONTROL ENVIRONMENT AND GOVERNANCE.....	7
2.1 Management's Responsibility for Controls.....	7
2.2 Control Environment Components.....	7
2.3 Organization Chart and Responsibilities.....	8
SECTION 3: CONTROL FRAMEWORK OVERVIEW.....	9
3.1 ISAE 3000 Control Categories.....	9
3.2 Control Effectiveness Assessment.....	9
SECTION 4: DETAILED CONTROL DESCRIPTIONS.....	10
CATEGORY A: POLICIES, GOVERNANCE & COMPLIANCE (3 Controls).....	10
CONTROL A.1: Establishment and Maintenance of Information Security Policies..	10
CONTROL A.2: Assignment of Information Security Responsibilities.....	12
CONTROL A.3: Competence and Awareness for Information Security.....	14
CATEGORY B: TECHNICAL SECURITY & SYSTEMS (14 Controls).....	16
CONTROL B.1: System Architecture and Design.....	16
CONTROL B.2: Operating System Hardening and Configuration.....	19
CONTROL B.3: Malware Protection and Prevention.....	21
CONTROL B.4: Network Security and Access Control.....	24
CONTROL B.5: Data Encryption in Transit and at Rest.....	26
CONTROL B.7: System Monitoring and Logging.....	32
CONTROL B.8: Backup and Recovery Systems.....	34
CONTROL B.9: Incident Response and Emergency Procedures.....	35
CONTROL B.10: Development and Testing Environments.....	35
CONTROL B.11: Vulnerability Assessment and Management.....	35
CONTROL B.12: Change Management.....	36
CONTROL B.13: Privileged Access and Administrative Functions.....	36
CONTROL B.14: Segregation of Duties and Conflict Resolution.....	37
CATEGORY C: PERSONNEL AND ORGANIZATION (7 Controls).....	37
CONTROL C.1-C.7 Summary:.....	37
CATEGORY D: DATA MANAGEMENT (3 Controls).....	37
CONTROL D.1: Data Retention and Disposal.....	37
CONTROL D.2: Secure Data Deletion.....	37
CONTROL D.3: Data Subject Access Requests.....	38
CATEGORY E: DATA ACCESS AND TRANSFER (2 Controls).....	38
CONTROL E.1: Controlled Data Access.....	38
CONTROL E.2: Secure Data Transfer.....	38
CATEGORY F: SUB-PROCESSOR MANAGEMENT (6 Controls).....	38



CONTROL F.1: Sub-processor Agreements.....	38
CONTROL F.2-F.6: Sub-processor Oversight.....	38
CATEGORY G: BACKUP AND RECOVERY (2 Controls).....	39
CONTROL G.1: Backup Strategy.....	39
CONTROL G.2: Recovery Testing.....	39
CATEGORY H: USER SUPPORT AND MANAGEMENT (2 Controls).....	39
CONTROL H.1: User Support and Assistance.....	39
CONTROL H.2: User Management.....	39
CATEGORY I: INCIDENT RESPONSE (4 Controls).....	39
CONTROL I.1: Incident Response Planning.....	39
CONTROL I.2: Incident Detection and Reporting.....	39
CONTROL I.3: Incident Investigation and Response.....	40
CONTROL I.4: Breach Notification.....	40
SECTION 5: MANAGEMENT'S ASSERTION.....	40
5.1 Management Responsibility Statement.....	40
5.2 Control Effectiveness Assessment.....	40
5.3 Regulatory Compliance Confirmation.....	40
5.4 Control Environment Summary.....	41
5.5 Management Sign-off.....	41
SECTION 6: APPENDICES.....	43
Appendix A: GDPR to ISAE Control Mapping.....	44
ISAE 3000 Type 1 Controls → GDPR Cyberday Mapping.....	44
Overview: ISAE 3000 Audit Scope.....	44
A – Controller Instructions.....	44
A.1 Processing Instructions & Procedure Review.....	44
A.2 Compliance with Processing Agreements.....	45
A.3 Reporting Potentially Unlawful Instructions.....	46
B – Technical and Physical Security Measures.....	46
B.1 Safeguards Implementation & Review.....	46
B.2 Risk Assessment & Technical Measures.....	47
B.3 Antivirus Protection & Updates.....	48
B.4 Firewall Protection for External Access.....	48
B.5 Network Segmentation.....	49
B.6 Access Control for Personal Data.....	49
B.7 System Monitoring & Alerts.....	50
B.8 Encryption for Internet/Email Transfers.....	51
B.9 Logging of User & Security Events.....	51
B.10 Pseudonymization/Anonymization in Dev/Test.....	52
B.11 Vulnerability Scans & Penetration Testing.....	53
B.12 Change & Patch Management.....	54
B.13 User Access Management & Periodic Review.....	55
B.14 Two-Factor Authentication for High-Risk Processing.....	55
B.15 Physical Access Safeguards.....	56
C – Organisational Measures.....	57



C.1 Information Security Policy & Management Approval.....	57
C.2 Policy Compliance with Data Processing Agreements.....	58
C.3 Employee Screening During Recruitment.....	58
C.4 Employee Confidentiality & Information Security Induction.....	59
C.5 Employee Offboarding: Access Removal & Asset Return.....	60
C.6 Continuation of Confidentiality Obligations Post-Departure.....	61
C.7 Security Awareness Training.....	62
D – Return and Deletion of Personal Data.....	63
D.1 Storage & Deletion Procedures & Annual Review.....	63
D.2 Retention Periods & Deletion Routines per Agreement.....	63
D.3 Return or Deletion Upon Termination.....	64
E – Storage and Processing Locations.....	65
E.1 Storage & Processing Procedure Aligned with DPA.....	65
E.2 Actual Processing/Storage Locations Match Approved Locations.....	66
F – Use of Sub-Processors.....	67
F.1 Sub-Processor Appointment Procedure & Annual Review.....	67
F.2 Sub-Processor Authorization & Register.....	68
F.3 Sub-Processor Change Notification & Approval.....	69
F.4 Data Protection Obligations Passed to Sub-Processors.....	70
F.5 Sub-Processor Register with Required Details.....	71
F.6 Sub-Processor Risk Assessment & Monitoring.....	71
G – Transfers to Third Countries.....	72
G.1 Third-Country Transfer Procedure & Annual Review.....	72
G.2 Transfers Follow Controller Instructions/Approvals.....	73
G.3 Transfer Mechanism & Supporting Assessment.....	74
H – Assistance with Data Subject Rights.....	76
H.1 Data Subject Rights Assistance Procedure & Annual Review.....	76
H.2 Capability to Assist with All Agreed Rights.....	77
I – Personal Data Breach Management.....	78
I.1 Breach Notification Procedure & Annual Review.....	78
I.2 Breach Identification Controls: Awareness, Monitoring, Log Review.....	79
I.3 24-Hour Notification to Controller.....	80
I.4 Assistance with Reports to Danish Data Protection Authority.....	82
Cyberday Framework Summary.....	83
Next Steps.....	84
Appendix B: ISO 27001:2022 to ISAE Control Mapping.....	85
ISO 27001:2022 to ISAE 3000 Control Mapping.....	85
Overview: ISO 27001:2022 Coverage.....	85
Alignment Model.....	85
CATEGORY 1: GOVERNANCE (8 Controls).....	86
ISO 27001 A.5.1 - Policies for Information Security.....	86
ISO 27001 A.5.2 - Information Security Roles and Responsibilities.....	86
ISO 27001 A.5.3 - Segregation of Duties.....	86
ISO 27001 A.5.4 - Management Responsibilities.....	86



ISO 27001 A.5.5 - Contact with Authorities.....	86
ISO 27001 A.5.6 - Contact with Special Interest Groups.....	87
ISO 27001 A.5.7 - Threat Intelligence.....	87
ISO 27001 A.5.8 - Use of Cryptography.....	87
CATEGORY 2: ASSET MANAGEMENT (7 Controls).....	87
ISO 27001 A.5.9 - Inventory of Information and Other Associated Assets.....	87
ISO 27001 A.5.10 - Acceptable Use of Information and Other Associated Assets....	88
ISO 27001 A.5.11 - Return of Assets.....	88
ISO 27001 A.5.12 - Classification of Information.....	88
ISO 27001 A.5.13 - Labelling of Information.....	88
ISO 27001 A.5.34 - Privacy and Protection of PII.....	88
CATEGORY 3: ACCESS MANAGEMENT (8 Controls).....	89
ISO 27001 A.5.15 - Access Control.....	89
ISO 27001 A.5.16 - Identity Management.....	89
ISO 27001 A.5.17 - Authentication Information.....	89
ISO 27001 A.5.18 - Rights of Access.....	89
ISO 27001 A.5.19 - Information Security in Supplier Relationships.....	90
ISO 27001 A.5.20 - Addressing Information Security Within Supplier Agreements..	90
ISO 27001 A.5.21 - Managing Information Security in the ICT Supply Chain.....	90
ISO 27001 A.5.22 - Monitoring, Review and Change Management of Supplier Services.....	90
CATEGORY 4: INFORMATION PROTECTION (7 Controls).....	91
ISO 27001 A.5.23 - Information Security for Use of Cloud Services.....	91
ISO 27001 A.5.24 - Planning and Preparing for Information Security Incident Handling.....	91
ISO 27001 A.5.25 - Assessment and Decision on Information Security Events.....	91
ISO 27001 A.5.26 - Response to Information Security Incidents.....	91
ISO 27001 A.5.27 - Learning from Information Security Incidents.....	92
ISO 27001 A.8.1 - User Endpoint Devices.....	92
ISO 27001 A.8.2 - User Authentication for External Connections.....	92
CATEGORY 5: PHYSICAL SECURITY (12 Controls).....	92
ISO 27001 A.7.1 - Physical Security Perimeters.....	92
ISO 27001 A.7.2 - Physical Entry.....	92
ISO 27001 A.7.3 - Securing Offices, Rooms and Facilities.....	93
ISO 27001 A.7.4 - Physical Security Monitoring.....	93
ISO 27001 A.7.5 - Protecting Against Physical and Environmental Threats.....	93
ISO 27001 A.7.6 - Working in Secure Areas.....	93
ISO 27001 A.7.7 - Delivery and Loading Areas.....	94
ISO 27001 A.8.3 - Managing Removable Media.....	94
ISO 27001 A.8.4 - Utility Supply.....	94
ISO 27001 A.8.5 - Cabling Security.....	94
ISO 27001 A.8.6 - Acquisition, Installation, Replacement and Removal of Equipment. 94	
CATEGORY 6: LEGAL & COMPLIANCE (6 Controls).....	95
ISO 27001 A.5.31 - Legal, Statutory, Regulatory and Contractual Requirements....	95



ISO 27001 A.5.32 - Intellectual Property Rights.....	95
ISO 27001 A.5.33 - Protection of Records.....	95
CATEGORY 7: HUMAN RESOURCE SECURITY (7 Controls).....	95
ISO 27001 A.6.1 - Screening.....	95
ISO 27001 A.6.2 - Terms and Conditions of Employment.....	96
ISO 27001 A.6.3 - Information Security Awareness, Education and Training.....	96
ISO 27001 A.6.4 - Disciplinary Process.....	96
ISO 27001 A.6.5 - Responsibilities after Termination or Change of Employment.....	96
ISO 27001 A.6.6 - Confidentiality or Non-Disclosure Agreements.....	97
ISO 27001 A.6.7 - Remote Working.....	97
CATEGORY 8: SYSTEM & NETWORK SECURITY (6 Controls).....	97
ISO 27001 A.8.7 - Protection Against Malware.....	97
ISO 27001 A.8.20 - Networks Security.....	97
ISO 27001 A.8.21 - Security of Network Services.....	97
ISO 27001 A.8.22 - Segregation of Networks.....	98
ISO 27001 A.8.23 - Web Filtering.....	98
ISO 27001 A.8.29 - Information Systems Resilience and Redundancy.....	98
CATEGORY 9: SECURE CONFIGURATION (4 Controls).....	98
ISO 27001 A.8.9 - Configuration Management.....	98
ISO 27001 A.8.10 - Information Deletion.....	99
ISO 27001 A.8.18 - Use of Privileged Utility Programs.....	99
ISO 27001 A.8.19 - Installation of Software on Operational Systems.....	99
CATEGORY 10: APPLICATION SECURITY (7 Controls).....	99
ISO 27001 A.8.25 - Secure Development Life Cycle.....	99
ISO 27001 A.8.26 - Application Security Requirements.....	99
ISO 27001 A.8.27 - Secure System Architecture and Engineering Principles.....	100
ISO 27001 A.8.28 - Secure Coding.....	100
ISO 27001 A.8.30 - Development, Testing and Production Environments.....	100
ISO 27001 A.8.31 - Change of Platform.....	100
ISO 27001 A.8.32 - Monitoring and Reviewing.....	101
CATEGORY 11: THREAT & VULNERABILITY MANAGEMENT (2 Controls).....	101
ISO 27001 A.8.8 - Management of Technical Vulnerabilities.....	101
CATEGORY 12: INFORMATION SECURITY EVENT MANAGEMENT (8 Controls).....	101
ISO 27001 A.5.25 - Assessment and Decision on Information Security Events.....	101
ISO 27001 A.5.26 - Response to Information Security Incidents.....	101
ISO 27001 A.5.27 - Learning from Information Security Incidents.....	101
CATEGORY 13: CONTINUITY MANAGEMENT (5 Controls).....	102
ISO 27001 A.5.29 - Information Security During Disruption.....	102
ISO 27001 A.5.30 - ICT Readiness for Business Continuity.....	102
ISO 27001 A.8.6 - Capacity Management.....	102
CATEGORY 14: FOUNDATION (Section 4: 23 Controls).....	102
ISO 27001 A.4.1 - Organization and its Context.....	102
ISO 27001 A.4.2 - Interested Parties.....	103
ISO 27001 A.4.3 - Scope of ISMS.....	103



COVERAGE SUMMARY.....	103
By Category.....	103
Key Findings.....	104
✓ EXCELLENT ALIGNMENT: 95% Coverage.....	104
Mapping ISO 27001:2022 → ISAE 3000 Controls.....	105
Direct Mappings (Highest Confidence).....	105
Recommendations.....	106
For ISAE 3000 Audit Using ISO 27001:2022.....	106
Appendix C: Evidence Reference and Cyberday Integration.....	107
Appendix D: Supporting Documentation Index.....	108
Appendix E: Contact Information.....	109
SECTION 7: DOCUMENT CONTROL.....	110



EXECUTIVE SUMMARY

Data & More ApS is a Danish service organization providing automated data compliance solutions to organizations across Europe. Our service assists customers in identifying, reporting, and managing illegal personal data in accordance with GDPR and other data protection regulations.

This Description of Processing outlines:

- **45 control objectives** organized across 9 control categories (A through I)
- **Control design** describing how each control is implemented
- **Operational procedures** showing how controls operate in practice
- **Effectiveness evidence** demonstrating control performance
- **Framework alignment** showing compliance with GDPR, ISO 27001:2022, and ISAE 3000 requirements

Key Facts:

- Organization Size: 30 employees (as of September 2026)
- Primary Service: Automated Data Compliance Solution
- Deployment: SaaS (Hetzner EU hosting) or On-Premises (client datacenter)
- Data Classification: Personal Identifiable Information (PII) / Compliance Data
- Data Processor Role: Yes (direct) and Sub-Data Processor (via partners)
- Regulatory Framework: GDPR, ISAE 3000, ISO 27001:2022



SECTION 1: SERVICE ORGANIZATION OVERVIEW

1.1 Organization Structure and History

Founded: October 2016

Headquarters: Denmark

Employees: 27 (as of June 2025)

Organizational Areas:

1. **Sales** - Customer acquisition and relationship management
2. **Customer Success** - Client onboarding and consultancy
3. **IT Services** - Infrastructure, support, and new feature development
4. **Business Services** - Finance, HR, compliance (internal support)

1.2 Service Description

Primary Service: Automated Data Compliance Solution

The Data & More platform helps organizations:

- Identify illegal or unnecessary personal data in their systems
- Report data protection issues to relevant parties
- Manage remediation of data protection violations
- Maintain ongoing compliance with GDPR and similar regulations

Service Delivery Models:

1. **SaaS Model** - Hosted on Hetzner infrastructure (EU datacenter, Germany)
2. **On-Premises Model** - Installed at client's chosen location or datacenter

Service Customers:

- Direct customers (Data & More is Data Processor)
- Sub-processor relationships (partner acts as controller/processor, Data & More is sub-processor)

1.3 Data Processing Activities

Types of Data Processed:

- Personal Identifiable Information (PII) - customer data from client organizations
- Compliance data - audit logs, processing records, system records
- Configuration data - client-specific settings and parameters

Processing Purposes:

- Data identification and classification
- Compliance reporting and alerting
- Audit trail maintenance



- System operation and support

Data Flow:

Client Systems



Data & More Platform (Hetzner EU or On-Premises)



Data Classification & Analysis



Compliance Reports



Client Access / Export

Data Storage Locations:

- Primary: Hetzner infrastructure (EU, Germany) - compliant with GDPR
- Secondary: Client on-premises infrastructure (when applicable)
- **Note:** No data transfers outside EU/EEA. All storage within EU or client-controlled facilities.

Data Retention:

- Retention periods defined in Data Processing Agreements with clients
- Standard retention: As specified by client requirements
- Deletion procedures: Implemented in control D.1-D.3 (see Section 4.4)

1.4 Regulatory Environment

Applicable Regulations:

- GDPR (General Data Protection Regulation) - primary regulatory framework
- ISAE 3000 (Revised) - audit standard for this description
- ISO 27001:2022 - information security management system
- Various national data protection laws
- Industry-specific regulations (as applicable to clients)

Compliance Certifications:

- ISAE 3000 Type 1 audit (current engagement)
- GDPR DPA compliance verified
- Penetration testing by external auditor (conducted)
- Employee GDPR training and certifications (ongoing)

Key Compliance Roles:

- Compliance Officer: Responsible for regulatory oversight (GDPR, ISAE, ISO)
- Data Protection Officer equivalent: Internal compliance review
- Certifications: DPO, CEP (Certified European Privacy), FAS certifications



SECTION 2: CONTROL ENVIRONMENT AND GOVERNANCE

2.1 Management's Responsibility for Controls

Management of Data & More ApS is responsible for:

1. **Designing** effective controls to achieve control objectives
2. **Implementing** controls in business processes and systems
3. **Maintaining** controls through periodic review and update
4. **Monitoring** control effectiveness through testing and evaluation
5. **Remediating** any identified control deficiencies

Management has assessed the control environment and confirmed:

- All 45 ISAE 3000 control objectives are designed appropriately
- Controls are implemented and operating effectively
- Zero critical deficiencies exist in control design or operation
- All GDPR compliance requirements are addressed through existing controls
- All ISO 27001:2022 security controls are supported by ISAE controls

2.2 Control Environment Components

1. Risk Assessment

- Data & More conducts regular risk assessments
- Risks identified: Data breach, unauthorized access, compliance violation
- Mitigation strategies documented in control B.11 (Vulnerability Management)
- Evidence: Risk Assessment Reports, Vulnerability Scans

2. Control Activities

- Preventive controls (access control, encryption, segregation of duties)
- Detective controls (logging, monitoring, audits)
- Corrective controls (incident response, breach notification)
- Organized in Section 4 (45 ISAE Controls)

3. Information and Communication

- Policies and procedures documented in control A.1 (Policies)
- Communication methods: Employee handbook, training, meetings
- Evidence: Policy documents, training records, meeting notes

4. Monitoring

- Continuous monitoring of access logs and system activity
- Periodic testing of control effectiveness



- Annual management review of control environment
- Evidence: Log files, test results, management review documents

5. Culture

- Commitment to compliance and data protection
- Regular employee training on GDPR and security
- All employees trained on policies and procedures
- Evidence: Training certificates, employee handbook

2.3 Organization Chart and Responsibilities

Executive Level:

- Owner/Management: Overall responsibility for control environment
- Compliance Officer: Regulatory compliance and GDPR oversight

Functional Areas:

Sales:

- Customer acquisition
- DPA negotiation and signature
- SLA definition

Customer Success:

- Client onboarding
- System configuration and training
- Support and consultation

IT Services:

- System maintenance and updates
- Infrastructure management
- Security and access control
- Feature development

Business Services:

- HR and employee management
- Finance and operations
- Internal compliance support



SECTION 3: CONTROL FRAMEWORK OVERVIEW

3.1 ISAE 3000 Control Categories

This Description of Processing addresses 45 control objectives organized into 9 categories:

Category	Controls	Focus Area
A	A.1 - A.3	Policies & Governance
B	B.1 - B.14	Technical Security & Systems
C	C.1 - C.7	Personnel & Organization
D	D.1 - D.3	Data Management & Retention
E	E.1 - E.2	Data Access & Transfer
F	F.1 - F.6	Sub-processor Management
G	G.1 - G.2	Backup & Recovery
H	H.1 - H.2	User Support & Access
I	I.1 - I.4	Incident Management

Total Controls: 45

Coverage Status: 100% mapped to GDPR and ISO 27001:2022

3.2 Control Effectiveness Assessment

Assessment Methodology:

- Design review: Confirm controls are designed to achieve objectives
- Implementation testing: Confirm controls are implemented
- Operating effectiveness testing: Confirm controls operate as designed

Assessment Period: July 18, 2025 - Sep 30, 2026

Results Summary:

- Controls designed appropriately: 45/45 (100%)
- Controls implemented: 45/45 (100%)
- Controls operating effectively: 45/45 (100%)
- Critical deficiencies: 0
- Remediation items: 0



SECTION 4: DETAILED CONTROL DESCRIPTIONS

CATEGORY A: POLICIES, GOVERNANCE & COMPLIANCE (3 Controls).

CONTROL A.1: Establishment and Maintenance of Information Security Policies

Control Objective:

Information security policies are established, documented, and maintained to govern the collection, use, protection, and disposal of personal data in accordance with GDPR and organizational requirements.

Control Category: Preventive

GDPR Alignment: Articles 5, 24, 32

ISO 27001:2022 Alignment: A.5.1 (Policies for information security)

Control Design:

1. Policy Documentation

- Comprehensive Information Security Policy exists
- Documents data protection principles and requirements
- Covers GDPR obligations and processor responsibilities
- Includes incident response, access control, and data retention procedures
- Accessible to all employees via employee handbook

2. Policy Scope

- Applies to all employees and contractors
- Covers all systems and data processing activities
- Addresses SaaS and on-premises deployments
- Requirements for data handling at all stages (collection, processing, retention, deletion)

3. Policy Review and Update

- Formal review: Annually (minimum)
- Updates: As needed based on regulatory changes or incident learnings
- Approval: By management and compliance officer
- Communication: To all affected personnel

4. Related Policies

- Data Protection Policy (specific to GDPR requirements)
- Information Security Policy (technical controls)



- Access Control Policy (user authentication and authorization)
- Incident Response Policy (breach notification)
- Data Retention Policy (storage and deletion)

Operating Procedures:

Quarterly Review Process:

1. Compliance officer reviews policy effectiveness
2. Any necessary updates identified
3. Updates approved by management
4. Updated policies communicated to all employees
5. Training scheduled for material changes

Annual Comprehensive Review:

1. Full review of all policies against regulatory requirements
2. Effectiveness assessment based on incidents and audit findings
3. Update to reflect regulatory changes or new risk areas
4. Board/management approval
5. Communication and training across organization

Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art5, ISO#A5.1, ISAE#A.1):

- Information Security Policy (current version with approval dates)
- Data Protection Policy (GDPR-specific requirements)
- Policy review and approval records
- Employee handbook (includes policy summaries)
- Training records (employees acknowledging policy receipt)
- Policy update history and change log

Control Effectiveness Evidence:

Testing Performed:

- Reviewed policies for completeness and GDPR alignment
- Confirmed all employees received policy training
- Inspected approval signatures and dates
- Verified annual review completion
- Confirmed policies are accessible to all personnel

Test Results:

- All 30 employees have signed policy acknowledgment
- Annual review completed on schedule
- Policies updated for 2025 GDPR requirements



- Zero policy violations identified

Cyberday Implementation:

- Evidence folder: Policies & Procedures → Information Security Policies
- Tags: GDPR#Art5, GDPR#Art24, GDPR#Art32, ISO#A5.1, ISAE#A.1
- Upload: Current policy documents, approval records, review documentation

CONTROL A.2: Assignment of Information Security Responsibilities

Control Objective:

Clear assignment of information security and data protection responsibilities ensures accountability for compliance with policies and procedures, and enables timely identification and resolution of control issues.

Control Category: Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.5.2 (Information security roles and responsibilities)

Control Design:

1. Responsibility Matrix

- Executive level: Overall responsibility for control environment
- Compliance Officer: Regulatory compliance oversight
- IT Manager: Technical controls and system security
- HR Manager: Personnel security and training
- Department Heads: Departmental compliance
- All Employees: Adherence to policies

2. Segregation of Duties

- System administrators: Access provisioning and management
- Compliance: Policy enforcement and monitoring
- Management: Control effectiveness review
- No individual has unilateral control over sensitive processes

3. Role Documentation

- Job descriptions include security responsibilities
- RACI matrix defining roles and accountability
- Updates when organizational structure changes
- Regular review of responsibility assignments

4. Training and Communication

- Employees trained on their specific responsibilities



- Clear escalation paths for security issues
- Regular communication of responsibility updates
- Acknowledgment of responsibilities by key personnel

Operating Procedures:

Onboarding Process:

1. New employee receives job description with security responsibilities
2. Assigned to compliance officer for policy training
3. Manager confirms understanding of responsibilities
4. Employee signs acknowledgment of responsibilities
5. Added to responsibility matrix and access control systems

Annual Responsibility Review:

1. Review of responsibility assignments against organizational changes
2. Update to RACI matrix and job descriptions
3. Communication of any responsibility changes
4. Retraining for changed responsibilities
5. Approval by management

Delegation and Escalation:

1. Temporary delegation requires management approval
2. Escalation paths for security issues clearly defined
3. Escalation testing performed during incident response drills
4. Responsibility matrix updated to reflect current assignments

Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art32, ISO#A5.2, ISAE#A.2):

- Job descriptions (with security responsibilities)
- RACI matrix (roles and accountability)
- Responsibility assignment acknowledgments
- Organizational chart
- Training records (security responsibility training)
- Escalation procedures and contact information

Control Effectiveness Evidence:

Testing Performed:

- Reviewed job descriptions for security responsibility inclusion
- Verified RACI matrix accuracy against current organization
- Confirmed all key personnel have responsibility acknowledgments
- Tested escalation procedures through drill



- Reviewed incidents for proper escalation

Test Results:

- All 30 employees have documented security responsibilities
- RACI matrix current and accurate
- Escalation procedures tested and effective
- All material incidents properly escalated
- Zero accountability gaps identified

Cyberday Implementation:

- Evidence folder: Organization & Governance → Roles and Responsibilities
- Tags: GDPR#Art32, ISO#A5.2, ISAE#A.2
- Upload: Job descriptions, RACI matrix, acknowledgments, escalation procedures

CONTROL A.3: Competence and Awareness for Information Security

Control Objective:

Employees and contractors possess and maintain the knowledge and skills required to fulfill their information security and data protection responsibilities, and are aware of their role in the control environment.

Control Category: Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.6.3 (Information and digital literacy)

Control Design:

1. Competence Requirements

- Data Protection Officer (DPO) level: Advanced GDPR training (obtained)
- Compliance roles: Intermediate GDPR and security training
- IT roles: Advanced technical security training
- All employees: Mandatory GDPR and security awareness training

2. Training Program

- Annual mandatory training: GDPR fundamentals and policies
- Role-specific training: Provided based on job responsibilities
- New hire training: Completed within 30 days of start date
- Specialized training: Data protection, incident response, access control
- Refresher training: At minimum annually; more frequently as needed

3. Training Methods



- Online courses (GDPR basics, security awareness)
- In-person workshops (incident response, specific tools)
- One-on-one coaching (role-specific knowledge)
- Documentation and self-study materials
- Annual review of training effectiveness

4. Competence Verification

- Training completion tracking
- Knowledge assessments for critical roles
- Supervisory evaluation of competence
- Incident response drills and testing
- Annual review of competence levels

Operating Procedures:

Annual Training Program:

1. Training curriculum reviewed and updated (H1 each year)
2. Training scheduled for all employees
3. Mandatory GDPR/security awareness: All employees
4. Role-specific training: Assigned based on RACI matrix
5. Training completion tracked and reported
6. Completion verification: Employee and manager sign-off

New Employee Onboarding:

1. Security awareness training: Within first week
2. Policy training: With compliance officer
3. Role-specific training: Within 30 days
4. Knowledge assessment: Before full system access
5. Ongoing coaching: From manager and peers

Training Records:

- Training attended: Documented in HR system
- Training completion: Signed by trainer and trainee
- Knowledge assessments: Scores and feedback recorded
- Refresher training: Tracked and scheduled
- Effectiveness evaluation: Conducted annually

Specialized Competencies:

- DPO certifications: Maintained for compliance officer
- Incident response training: For designated personnel
- Data handling procedures: For all data processing staff
- Technical security: For IT personnel



Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art32, ISO#A6.3, ISAE#A.3):

- Training curriculum and materials
- Training records for all employees
- Completion certificates
- Knowledge assessment results
- Training effectiveness evaluation reports
- Specialized certification records (DPO, incident response, etc.)
- Training attendance sign-in sheets
- Job descriptions with competence requirements

Control Effectiveness Evidence:

Testing Performed:

- Reviewed training records for all 30 employees
- Verified annual training completion
- Assessed training effectiveness through incident response
- Tested employee knowledge of key policies
- Reviewed specialized certifications and training
- Verified new hire training completion

Test Results:

- All 30 employees completed annual GDPR/security training
- 100% training completion rate
- Specialized personnel hold required certifications
- Incident response drills demonstrated adequate competence
- Zero policy violations due to lack of knowledge
- Training effectiveness confirmed through incident handling quality

Cyberday Implementation:

- Evidence folder: Personnel & Training → Competence and Awareness
- Tags: GDPR#Art32, ISO#A6.3, ISAE#A.3
- Upload: Training curriculum, certificates, attendance records, assessment results

CATEGORY B: TECHNICAL SECURITY & SYSTEMS (14 Controls)

CONTROL B.1: System Architecture and Design

Control Objective:

System architecture and design incorporate security principles including layered security, segregation of duties, encryption, and defense-in-depth to protect the confidentiality, integrity, and availability of client data.



Control Category: Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.5.23 (Encryption and key management), A.8.27 (Protection of system architecture)

Control Design:

1. Architectural Principles

- Defense-in-depth: Multiple layers of security controls
- Least privilege: Minimal necessary access
- Segregation: Separation of duties and environments
- Encryption: Data at rest and in transit
- Logging: Comprehensive audit trails
- Resilience: High availability and disaster recovery

2. System Components

- Load balancers: Distribute traffic and enable failover
- Application servers: Core processing logic
- Database servers: Data storage with encryption
- Cache servers: Performance optimization
- Backup systems: Data recovery capability
- Logging systems: Security event capture

3. Environment Segregation

- Development: Code development and testing
- Staging: Pre-production testing and validation
- Production: Live client data processing
- Security testing: Penetration testing environment
- Each environment isolated with restricted access

4. Network Architecture

- DMZ: External-facing systems
- Internal network: Core processing systems
- Database network: Encrypted, restricted access
- Management network: Administrative access only
- Firewalls: Network segmentation and access control
- VPN: Secure remote access

Operating Procedures:

System Design Review:

1. All new systems designed with security principles



2. Security architecture review before implementation
3. Threat modeling: Identify potential attack vectors
4. Security controls mapped to identified threats
5. Approval by IT Manager and Compliance Officer

Environment Management:

1. Development changes isolated from production
2. Staged deployment through dev → staging → production
3. Testing in each environment before production release
4. Access controls strictly enforced for each environment
5. Production environment changes documented and approved

Architecture Updates:

1. Architectural changes require design review
2. Impact assessment on security and data protection
3. Testing requirements defined before implementation
4. Monitoring plan established for changes
5. Rollback procedure defined for each change

Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art32, ISO#A5.23, ISO#A8.27, ISAE#B.1):

- System architecture diagrams
- Network topology and segmentation documentation
- Environment definitions and purpose
- Access control mappings
- Encryption implementation details
- Disaster recovery and backup architecture
- Design review records and approvals
- Security testing results

Control Effectiveness Evidence:

Testing Performed:

- Reviewed system architecture documentation
- Verified network segmentation and firewall rules
- Tested environment isolation and access controls
- Confirmed encryption implementation (data at rest and in transit)
- Validated backup system functionality
- Reviewed audit logging on key systems
- Verified disaster recovery procedures



Test Results:

- Architecture follows security principles
- Environment segregation confirmed
- Encryption implemented for sensitive data
- Network segmentation effective
- Backup systems functional and tested
- Audit logs comprehensive and protected

Cyberday Implementation:

- Evidence folder: Technical Controls → System Architecture
- Tags: GDPR#Art32, ISO#A5.23, ISO#A8.27, ISAE#B.1
- Upload: Architecture diagrams, network documentation, security testing results

CONTROL B.2: Operating System Hardening and Configuration

Control Objective:

Operating systems are hardened and configured securely to minimize vulnerabilities and reduce the attack surface, including disabling unnecessary services and applying security baselines.

Control Category: Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.8.9 (Configuration management), A.8.12 (Security of system installations)

Control Design:

1. Hardening Standards

- Industry security baselines applied
- Unnecessary services disabled
- Security updates applied proactively
- Configuration consistency enforced
- Regular review and update of baselines

2. Configuration Management

- Documented standard configurations for each OS
- Configuration versioning and change control
- Approved configurations for different system roles
- Automated configuration deployment
- Compliance monitoring and remediation



3. Patch Management

- Security patches applied within 30 days (critical)
- Patches tested before production deployment
- Patch tracking and verification
- Emergency patching procedures for critical vulnerabilities
- System restart scheduling and coordination

4. Monitoring and Compliance

- Automated scanning for configuration drift
- Regular compliance verification
- Non-compliant systems quarantined or remediated
- Configuration changes logged and audited
- Periodic manual review of critical systems

Operating Procedures:

Baseline Development:

1. Industry standards reviewed (CIS benchmarks, NIST guidelines)
2. Baseline developed for each OS type
3. Baseline tested in staging environment
4. Security review and approval
5. Documentation of baseline with rationale for each setting

Configuration Deployment:

1. New systems provisioned with approved baseline
2. Configuration verification before production use
3. Configuration changes tracked and logged
4. Approval required for configuration deviations
5. Regular compliance verification

Patch Management Process:

1. Security advisories monitored continuously
2. Patches assessed for priority and impact
3. Testing in non-production environment
4. Deployment scheduling and coordination
5. Verification of patch application
6. Rollback procedures defined for each patch

Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art32, ISO#A8.9, ISO#A8.12, ISAE#B.2):

- OS hardening standards and baselines



- Configuration management procedures
- Patch management policy and schedules
- Configuration compliance reports
- Patch application records
- System hardening verification results
- Monitoring and remediation procedures

Control Effectiveness Evidence:

Testing Performed:

- Reviewed OS hardening standards
- Verified baseline configuration on sample systems
- Tested patch application process
- Confirmed security updates applied
- Validated configuration monitoring tools
- Reviewed patch deployment logs

Test Results:

- All systems comply with hardening baselines
- Critical patches applied within required timeframe
- Configuration drift monitoring active
- Non-compliant systems remediated promptly
- Patch application verified on all systems

Cyberday Implementation:

- Evidence folder: Technical Controls → System Hardening
- Tags: GDPR#Art32, ISO#A8.9, ISO#A8.12, ISAE#B.2
- Upload: Hardening baselines, patch logs, compliance reports

CONTROL B.3: Malware Protection and Prevention

Control Objective:

Malware protection mechanisms are implemented and maintained to detect and prevent malicious software from compromising systems and data, including antivirus, anti-malware, and endpoint detection and response (EDR) tools.

Control Category: Detective/Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.8.7 (Prevention of malware)



Control Design:

1. Malware Detection Tools

- Antivirus software on all endpoints
- Anti-malware tools on servers
- Endpoint Detection and Response (EDR) on critical systems
- Centralized management and monitoring
- Regular update of virus signatures and detection rules

2. Scanning and Monitoring

- Real-time scanning of file access and execution
- Scheduled full system scans
- Email attachment scanning
- External media scanning
- Quarantine of suspicious files for analysis

3. Web Protection

- URL filtering and blocking of malicious sites
- Browser protection tools
- Phishing detection and prevention
- Safe browsing warnings
- Email security gateway

4. Incident Response

- Procedures for handling malware incidents
- System isolation procedures
- Evidence preservation for forensic analysis
- Remediation and restoration procedures
- Notification procedures (if data breach occurs)

Operating Procedures:

Malware Protection Deployment:

1. Approved tools selected and tested
2. Deployed to all endpoints and servers
3. Configuration standardized across systems
4. Monitoring and alerting enabled
5. Exclusions documented and justified

Signature and Rule Updates:

1. Updates configured for automatic deployment
2. Updates validated before production deployment



3. Deployment schedules coordinated
4. Verification of update application
5. Monitoring for update-related issues

Malware Incident Procedure:

1. Detection and alerting
2. Immediate isolation of affected system
3. Threat analysis and identification
4. System cleanup and remediation
5. Restore from backup if necessary
6. Root cause analysis
7. Prevention of recurrence
8. Notification to affected parties (if required)

Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art32, ISO#A8.7, ISAE#B.3):

- Malware protection tool inventory and versions
- Configuration standards and settings
- Deployment and update logs
- Scanning and detection reports
- Incident reports and resolution
- Test results of malware detection

Control Effectiveness Evidence:

Testing Performed:

- Verified malware protection tools installed on all systems
- Reviewed update and signature currency
- Tested detection capabilities with safe malware test files
- Confirmed alert and response procedures
- Reviewed incident logs for malware detections
- Validated isolation and remediation procedures

Test Results:

- All systems protected with current tools
- Signatures and rules up-to-date
- Detection capabilities verified
- Zero successful malware infections in audit period
- Incidents properly isolated and remediated

Cyberday Implementation:

- Evidence folder: Technical Controls → Malware Protection



- Tags: GDPR#Art32, ISO#A8.7, ISAE#B.3
- Upload: Tool inventory, configuration, scan reports, incident logs

CONTROL B.4: Network Security and Access Control

Control Objective:

Network security controls prevent unauthorized access to systems and data, including firewalls, network segmentation, access control lists, and monitoring of network traffic.

Control Category: Preventive/Detective

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.8.20 (Network security), A.8.22 (Network segregation)

Control Design:

1. Firewall Protection

- Perimeter firewalls control external traffic
- Internal firewalls segment network zones
- Default-deny policy: Only approved traffic allowed
- Rules documented and justified
- Regular review and cleanup of rules

2. Network Segmentation

- DMZ: External-facing systems isolated
- Internal network: Core processing systems
- Database network: Restricted access only
- Management network: Administrative access only
- Guest network: Isolated from production systems

3. Access Control

- Network Access Control (NAC) for endpoint authentication
- VLAN segregation for different access levels
- MAC address filtering where appropriate
- Port-based access control
- Logging of connection attempts and denials

4. Traffic Monitoring

- Network traffic monitoring and analysis
- Intrusion detection systems (IDS)
- Suspicious traffic alerting
- DDoS protection and mitigation
- Performance monitoring and optimization



5. Remote Access

- VPN for secure remote connections
- Multi-factor authentication for VPN access
- VPN session monitoring and logging
- Restricted access based on need
- Automatic disconnection after inactivity

Operating Procedures:

Firewall Rule Management:

1. Rule requests submitted with business justification
2. Security review of proposed rules
3. Testing in non-production environment
4. Approved rules documented
5. Deployment with audit logging
6. Quarterly review and cleanup of unused rules

Network Segmentation:

1. Network design documented
2. Segmentation enforced by firewalls
3. Access between segments restricted and logged
4. Segment-to-segment traffic monitored
5. Changes to segmentation require security review

Access Control Configuration:

1. VLAN assignments based on role and function
2. Port-based access control configured
3. Access control lists reviewed regularly
4. Changes to ACLs logged and tracked
5. Compliance verified through testing

Remote Access Management:

1. VPN infrastructure maintained and updated
2. Access credentials managed securely
3. Session monitoring and logging
4. Session timeout configuration enforced
5. Suspicious activity alerts

Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art32, ISO#A8.20, ISO#A8.22, ISAE#B.4):

- Network architecture and topology diagrams



- Firewall rule documentation and justification
- Access control lists and configurations
- Network segmentation documentation
- VPN configuration and access logs
- Traffic monitoring and analysis reports
- Network access incidents and resolution

Control Effectiveness Evidence:

Testing Performed:

- Reviewed firewall configurations and rules
- Verified network segmentation implementation
- Tested network access controls
- Monitored network traffic for suspicious activity
- Verified VPN access controls and logging
- Tested incident response for network security events
- Reviewed access logs for unauthorized attempts

Test Results:

- Firewall rules properly configured and documented
- Network segmentation effective
- Access controls functioning as designed
- No unauthorized network access detected
- VPN access properly controlled and monitored
- Malicious traffic detected and blocked

Cyberday Implementation:

- Evidence folder: Technical Controls → Network Security
- Tags: GDPR#Art32, ISO#A8.20, ISO#A8.22, ISAE#B.4
- Upload: Network diagrams, firewall rules, access logs, monitoring reports

CONTROL B.5: Data Encryption in Transit and at Rest

Control Objective:

Data encryption protects the confidentiality and integrity of personal data in transit and at rest, preventing unauthorized disclosure or modification of data.

Control Category: Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.5.23 (Encryption and key management), A.8.24 (Data encryption)



Control Design:

1. Encryption at Rest

- Database encryption: AES-256 or equivalent
- Encryption of backups and archived data
- Encryption of removable media
- Encryption of data on cloud storage
- Consistent encryption standards applied

2. Encryption in Transit

- TLS 1.2 or higher for data transmission
- HTTPS for web communications
- VPN or encrypted tunnels for remote access
- Encrypted email for sensitive data transmission
- Certificate management and renewal

3. Key Management

- Encryption keys stored securely
- Key rotation procedures implemented
- Master key protection
- Key backup and recovery procedures
- Access to keys restricted to authorized personnel

4. Encryption Standards

- Industry-standard algorithms (AES, RSA, etc.)
- Regular review of encryption standards
- Update of algorithms as standards evolve
- Cryptographic agility for algorithm changes
- Documentation of encryption implementation

Operating Procedures:

Data Encryption Deployment:

1. Encryption requirements defined for data types
2. Encryption method selected and justified
3. Key management procedures established
4. Implementation tested in staging
5. Production deployment with monitoring

Key Management Process:

1. Key generation: Secure random generation
2. Key storage: Hardware security modules or protected storage



3. Key rotation: Periodic regeneration of keys
4. Key archival: Secure retention of old keys for decryption
5. Key destruction: Secure erasure when no longer needed

Encryption Verification:

1. Encryption enabled on all systems
2. Encryption effectiveness verified
3. Key management procedures validated
4. Performance impact of encryption assessed
5. Regular testing of encryption and decryption

Certificate Management:

1. SSL/TLS certificates obtained and installed
2. Certificate validity verified
3. Certificate renewal scheduled
4. Certificate revocation procedures established
5. Monitoring for certificate expiration

Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art32, ISO#A5.23, ISO#A8.24, ISAE#B.5):

- Encryption inventory and standards
- Key management procedures
- Encryption implementation documentation
- Key storage and protection details
- Certificate inventory and expiration dates
- Encryption effectiveness test results
- Key rotation and management records

Control Effectiveness Evidence:

Testing Performed:

- Verified encryption enabled on all systems
- Reviewed encryption algorithms and standards
- Tested key management procedures
- Verified TLS certificate validity and configuration
- Confirmed data encryption in transit and at rest
- Tested encryption of backups
- Validated key rotation procedures

Test Results:

- All sensitive data encrypted at rest (AES-256)
- All data in transit encrypted (TLS 1.2+)



- Key management procedures effective
- Certificates current and valid
- Encryption algorithms meet standards
- No unencrypted sensitive data detected
- Key rotation performed on schedule

Cyberday Implementation:

- Evidence folder: Technical Controls → Data Encryption
- Tags: GDPR#Art32, ISO#A5.23, ISO#A8.24, ISAE#B.5
- Upload: Encryption standards, key management procedures, certificate inventory

CONTROL B.6: Access Control and Authentication

Control Objective:

Access to systems and data is restricted through authentication and authorization controls to ensure that only authorized personnel access systems and data appropriate to their role.

Control Category: Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.5.15 (Access control), A.5.16 (Identity management)

Control Design:

1. User Identification and Authentication

- Unique user IDs for all system users
- Strong password policy (minimum 12 characters, complexity requirements)
- Multi-factor authentication (MFA) for critical systems
- MFA for remote access and administrative functions
- Periodic password changes (90 days for privileged accounts)

2. Authorization and Access Control

- Role-based access control (RBAC)
- Principle of least privilege
- Access control matrix defining role permissions
- Regular review of access assignments
- Access removal upon role change or termination

3. Privileged Access Management

- Separate privileged user accounts for administrative access
- Privileged access approval process
- Privileged session recording and monitoring
- Restrictions on privileged access (time-based, IP-based)
- Regular audit of privileged access usage

4. System Access Control



- Operating system-level access controls
- Application-level access controls
- Database access controls
- API access controls
- Access to configuration and system files restricted

Operating Procedures:

User Account Management:

1. Access request submitted with business justification
2. Manager approval of access request
3. Compliance review for GDPR compliance
4. Account creation with appropriate permissions
5. Employee training on access and security
6. User signs access agreement

Access Provisioning:

1. Access to systems based on role
2. Access restricted to necessary systems and functions
3. Access configured in central identity management
4. Access verified before full access granted
5. Notification to user and manager of access granted

Access Review Process:

1. Quarterly access review by managers
2. Removal of access no longer needed
3. Investigation of unusual access patterns
4. Follow-up for access not reviewed
5. Management sign-off on access review

Account Termination:

1. Termination notice triggers access review
2. Access removal effective immediately upon termination
3. System access verified as removed
4. Equipment return verified
5. Post-termination access verification

Privileged Access Management:

1. Privileged access requests require management approval
2. Compliance review for appropriateness
3. Access granted for limited duration if applicable
4. Session recorded and monitored



5. Post-session review of actions performed

Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art32, ISO#A5.15, ISO#A5.16, ISAE#B.6):

- User access policies and procedures
- Password policy and complexity requirements
- MFA implementation and configuration
- Access control matrix and role definitions
- User account inventory
- Access provisioning and removal requests
- Quarterly access reviews
- Privileged access logs
- Account termination procedures

Control Effectiveness Evidence:

Testing Performed:

- Reviewed user account creation and provisioning procedures
- Verified password complexity requirements enforced
- Confirmed MFA enabled on all systems
- Tested access control enforcement
- Reviewed access provisioning and removal logs
- Verified quarterly access reviews completed
- Tested privileged access controls and monitoring
- Reviewed account termination procedures

Test Results:

- All user accounts have unique identifiers
- Password policies enforced across all systems
- MFA required for administrative and remote access
- Access control matrix properly configured
- Least privilege principle enforced
- Quarterly access reviews completed
- Privileged access properly monitored
- Terminated employee access removed immediately
- Zero unauthorized access detected

Cyberday Implementation:

- Evidence folder: Technical Controls → Access Control
- Tags: GDPR#Art32, ISO#A5.15, ISO#A5.16, ISAE#B.6
- Upload: Access policies, user inventory, access logs, quarterly reviews



CONTROL B.7: System Monitoring and Logging

Control Objective:

Comprehensive logging and monitoring of system activity enables detection of security events, troubleshooting of issues, and investigation of incidents while maintaining audit trails for compliance.

Control Category: Detective

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.8.15 (Logging), A.8.32 (Monitoring system activity)

Control Design:

1. Logging Infrastructure

- Log aggregation from all systems
- Centralized log storage and analysis
- Log retention for audit and investigation
- Log protection against unauthorized modification
- Automated log rotation and archival

2. Event Logging

- User authentication attempts (success and failure)
- Access to sensitive data
- System configuration changes
- Privilege escalation attempts
- Backup and recovery operations
- Administrator activity

3. Real-Time Monitoring

- Security event alerts
- Anomaly detection
- Automated response to critical events
- Performance and capacity monitoring
- Availability monitoring

4. Log Analysis and Review

- Daily review of security alerts
- Weekly analysis of log trends
- Monthly comprehensive security review
- Investigation of anomalies and incidents
- Performance trend analysis

Operating Procedures:



Log Collection and Storage:

1. All systems configured to send logs
2. Log format standardized across systems
3. Logs transmitted securely to central repository
4. Log storage protected and encrypted
5. Log retention: Minimum 90 days (configurable per data type)

Security Monitoring:

1. Security tools configured to alert on key events
2. Alerts reviewed daily by IT team
3. Alerts escalated based on severity
4. Incident investigation procedures triggered for critical alerts
5. Lessons learned captured for prevention

Log Analysis:

1. Daily review of alert summary
2. Weekly trend analysis
3. Monthly comprehensive review by IT and compliance
4. Anomalies investigated
5. Root causes identified and documented

Incident Investigation:

1. Logs searched for evidence related to incident
2. Timeline of events reconstructed
3. User actions and data access reviewed
4. Evidence preserved for further analysis
5. Findings documented and shared

Supporting Evidence:

Documentation (Cyberday Tags: GDPR#Art32, ISO#A8.15, ISO#A8.32, ISAE#B.7):

- Logging infrastructure design
- Log collection and analysis procedures
- Logging configuration on all systems
- Log retention and archival procedures
- Security alert definitions and thresholds
- Daily and weekly monitoring reports
- Monthly security review reports
- Incident investigation logs and findings

Control Effectiveness Evidence:



Testing Performed:

- Verified logging enabled on all systems
- Reviewed log collection and centralization
- Confirmed log protection and encryption
- Tested alert generation and escalation
- Verified daily monitoring review
- Reviewed incident investigation process
- Confirmed log retention and archival
- Validated log integrity and protection

Test Results:

- Logging comprehensive and centralized
- Log protection effective
- Real-time monitoring and alerting operational
- Security events properly detected and investigated
- No gaps in logging coverage
- Log retention procedures followed
- Incident investigations thorough and documented

Cyberday Implementation:

- Evidence folder: Technical Controls → Monitoring and Logging
- Tags: GDPR#Art32, ISO#A8.15, ISO#A8.32, ISAE#B.7
- Upload: Logging procedures, monitoring reports, incident investigations

CONTROL B.8: Backup and Recovery Systems

Control Objective:

Data backup and recovery systems ensure that data can be recovered in case of loss, corruption, or disaster, and that recovery time objectives (RTO) and recovery point objectives (RPO) are met.

Control Category: Detective/Corrective

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.8.13 (Backup procedures)

Key Procedures:

- Daily incremental backups with weekly full backups
- Offsite backup storage (separate datacenter)
- Encrypted backup transmission and storage
- Regular backup restoration testing (quarterly)
- RTO/RPO defined per data criticality
- Recovery procedures documented and tested



CONTROL B.9: Incident Response and Emergency Procedures

Control Objective:

Incident response procedures enable rapid and effective response to security incidents, minimizing impact and enabling recovery and root cause analysis.

Control Category: Detective/Corrective

GDPR Alignment: Articles 33-34 (Breach notification), Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.5.24-27 (Incident response), A.8.34 (Incident handling)

Key Procedures:

- Incident response team identified and trained
- Incident severity classification
- Notification procedures (internal and external)
- Incident investigation and root cause analysis
- Containment and remediation procedures
- Post-incident review and lessons learned

CONTROL B.10: Development and Testing Environments

Control Objective:

Development and testing environments are isolated from production to prevent inadvertent disclosure of production data or introduction of vulnerabilities into production systems.

Control Category: Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.8.30 (Development and testing environments)

Key Procedures:

- Separate development, testing, and production environments
- Test data used instead of production data
- Code review before promotion to production
- Automated testing and security scanning
- Access controls restrict promotion to production

CONTROL B.11: Vulnerability Assessment and Management

Control Objective:

Vulnerability assessments identify potential security weaknesses in systems, and vulnerability management procedures ensure timely remediation of identified vulnerabilities.

Control Category: Detective/Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.8.8 (Management of technical vulnerabilities)

Key Procedures:



- Regular vulnerability scanning (monthly minimum)
- Penetration testing (annually)
- Vulnerability severity assessment
- Remediation prioritized by severity and exploitability
- Patch management process (see B.2)
- Remediation verification and testing
- External penetration testing conducted annually

CONTROL B.12: Change Management

Control Objective:

Change management procedures ensure that changes to systems and configurations are authorized, tested, and implemented with minimal risk to the confidentiality, integrity, and availability of data.

Control Category: Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.8.31 (Change of platform, operating system or applications)

Key Procedures:

- Change request process with documentation
- Impact assessment for security and availability
- Testing in non-production environment
- Change approval by authorized personnel
- Implementation scheduling and coordination
- Post-implementation verification
- Rollback procedures documented

CONTROL B.13: Privileged Access and Administrative Functions

Control Objective:

Privileged access to systems and administrative functions is strictly controlled, monitored, and restricted to authorized personnel to prevent unauthorized system changes or data access.

Control Category: Preventive/Detective

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.5.18 (Rights of access), A.8.18 (Use of privileged utility programs)

Key Procedures:

- Privileged access separated from normal access
- Separate privileged user accounts
- Privileged access approval and monitoring



- Session recording for privileged activities
- Restrictions on simultaneous privileged access
- Just-in-time (JIT) access granting when applicable

CONTROL B.14: Segregation of Duties and Conflict Resolution

Control Objective:

Segregation of duties prevents any single individual from controlling both the authorization and execution of sensitive functions, reducing the risk of fraud or unauthorized changes.

Control Category: Preventive

GDPR Alignment: Article 32 (Security of processing)

ISO 27001:2022 Alignment: A.5.3 (Segregation of duties)

Key Procedures:

- Conflicting duties identified and documented
- Access controls prevent simultaneous performance of conflicting duties
- Compensating controls where segregation not possible
- Regular review of duty segregation
- Monitoring of duty conflicts and exceptions

CATEGORY C: PERSONNEL AND ORGANIZATION (7 Controls)

CONTROL C.1-C.7 Summary:

- C.1: Background screening and verification
- C.2: Confidentiality and security agreements
- C.3: Training and awareness (separate from A.3 - role-specific)
- C.4: Disciplinary procedures
- C.5: Termination procedures
- C.6: Security incident reporting procedures
- C.7: Post-employment responsibilities

CATEGORY D: DATA MANAGEMENT (3 Controls)

CONTROL D.1: Data Retention and Disposal

Control Objective:

Data is retained only for as long as necessary to fulfill its purpose, and is securely disposed of when no longer required, in compliance with GDPR and customer contracts.

CONTROL D.2: Secure Data Deletion

Control Objective:

Deletion of data is permanent and irreversible, using methods that prevent recovery of deleted data from storage media.



CONTROL D.3: Data Subject Access Requests

Control Objective:

Requests from data subjects to access their personal data are processed in a timely manner and in compliance with GDPR requirements.

CATEGORY E: DATA ACCESS AND TRANSFER (2 Controls)

CONTROL E.1: Controlled Data Access

Control Objective:

Access to personal data is restricted to authorized personnel and granted based on legitimate business need and documented authorization.

CONTROL E.2: Secure Data Transfer

Control Objective:

Transfer of data between Data & More and customers is performed securely using encrypted channels and documented procedures.

CATEGORY F: SUB-PROCESSOR MANAGEMENT (6 Controls)

CONTROL F.1: Sub-processor Agreements

Control Objective:

Data Processing Agreements with sub-processors include appropriate security, confidentiality, and compliance obligations, and are executed before sub-processor engagement.

Key Procedures:

- DPA templates with standard security clauses
- Standard Contractual Clauses (SCCs) included
- Security requirements specified
- Sub-processor review and approval
- DPA signed before sub-processor access to data

CONTROL F.2-F.6: Sub-processor Oversight:

- F.2: Sub-processor authorization and notification
- F.3: Sub-processor change management
- F.4: Security requirements in sub-processor contracts
- F.5: Sub-processor security verification
- F.6: Sub-processor security monitoring and audits



CATEGORY G: BACKUP AND RECOVERY (2 Controls)

CONTROL G.1: Backup Strategy

Control Objective:

Backup strategy ensures regular, secure backups of critical data with defined recovery time and recovery point objectives.

CONTROL G.2: Recovery Testing

Control Objective:

Regular testing of backup and recovery procedures ensures that data can be recovered successfully in case of need.

CATEGORY H: USER SUPPORT AND MANAGEMENT (2 Controls)

CONTROL H.1: User Support and Assistance

Control Objective:

User support functions are provided with appropriate security controls to prevent unauthorized access or disclosure of information.

CONTROL H.2: User Management

Control Objective:

User account lifecycle management (creation, modification, deactivation, deletion) is controlled and documented.

CATEGORY I: INCIDENT RESPONSE (4 Controls)

CONTROL I.1: Incident Response Planning

Control Objective:

Incident response procedures are documented, tested, and maintained to enable rapid and effective response to security incidents.

Key Procedures:

- Incident response team identified
- Escalation procedures defined
- Communication procedures established
- Incident investigation procedures
- Post-incident review procedures

CONTROL I.2: Incident Detection and Reporting

Control Objective:

Security incidents are detected through monitoring and logging systems, and are reported to appropriate personnel for investigation.



CONTROL I.3: Incident Investigation and Response

Control Objective:

Security incidents are investigated to determine scope, impact, and root cause, and appropriate responses are implemented to contain and remediate the incident.

CONTROL I.4: Breach Notification

Control Objective:

In the event of a personal data breach, notification procedures ensure timely notification to affected individuals and regulators as required by GDPR.

Key Procedures:

- Breach notification procedures documented
- Timelines: Assessment within 72 hours, notification as required
- Communication with customers, regulators, and individuals
- Documentation of breach and notification
- Lessons learned and prevention of recurrence

SECTION 5: MANAGEMENT'S ASSERTION

5.1 Management Responsibility Statement

Management of Data & More ApS is responsible for:

1. **Designing** information security controls to achieve the control objectives
2. **Implementing** the controls in accordance with their design
3. **Maintaining** the controls to ensure continued effectiveness
4. **Monitoring** and evaluating the effectiveness of the controls

5.2 Control Effectiveness Assessment

Based on our assessment of the control design and operating effectiveness:

ASSERTION: All 45 ISAE 3000 Type 1 control objectives have been designed appropriately and are operating effectively to achieve their stated objectives.

Assessment Basis:

- Design review: 45/45 controls properly designed
- Implementation verification: 45/45 controls implemented
- Effectiveness testing: 45/45 controls operating effectively
- Testing period: July 18, 2024 - July 18, 2025

5.3 Regulatory Compliance Confirmation

Management confirms the following:



GDPR Compliance:

- ✓ 30 of 42 GDPR requirements are directly addressed by ISAE controls (71% coverage)
- ✓ Data Subject Rights (Article 12-13): Processor model - DSRs received from clients
- ✓ Data Processing Agreements (Article 28): Standard Contractual Clauses in place
- ✓ Breach Notification (Article 33): Procedures in standard DPA and Control I.4
- ✓ Data Protection Impact Assessment (Article 35): DPIA process implemented for all releases
- ✓ International Data Transfers (Article 44-49): Not applicable - all data in Hetzner EU or on-premises

ISO 27001:2022 Alignment:

- ✓ 110 of 116 ISO 27001:2022 controls are supported by ISAE controls (95% coverage)
- ✓ All operational security controls aligned
- ✓ Governance and organizational controls provide baseline support

5.4 Control Environment Summary

Zero Critical Gaps Identified:

- All 45 ISAE controls are implemented and operating effectively
- No design deficiencies identified
- No operating deficiencies identified
- All GDPR requirements addressed
- All major security areas covered

Control Deficiencies:

- None identified

Exceptions and Compensating Controls:

- None required

5.5 Management Sign-off

We, the management of Data & More ApS, attest that:

1. The control objectives described in this document are appropriate for the services we provide
2. The controls have been designed appropriately to achieve the stated objectives
3. The controls were operating effectively throughout the audit period
4. The description of our service organization is complete and accurate
5. We have disclosed all material facts affecting the control environment



Authorized by:

[Signature block for Management]

.



SECTION 6: APPENDICES



Appendix A: GDPR to ISAE Control Mapping

ISAE 3000 Type 1 Controls → GDPR Cyberday Mapping

Prepared for: Elumi

Framework: ISAE 3000 Type 1 Audit for GDPR Compliance

Primary Reference: General Data Protection Regulation (GDPR)

Supporting Framework: SOC 2, ISO 27001, ISO 27701

Date: 2026-10-02

Overview: ISAE 3000 Audit Scope

ISAE 3000 is the assurance standard used to audit **GDPR compliance** for data processors. This mapping connects each ISAE 3000 control to the specific **GDPR Articles** that define the requirements being assessed.

GDPR Cyberday Coverage:

- **42 total requirements** mapped across 5 sections
 - **Controller and Processor Obligations** (Art 24-39): 16 requirements
 - **Data Subject Rights** (Art 12-23): 12 requirements
 - **Principles** (Art 5-11): 7 requirements
 - **Third-Country Transfers** (Art 44-49): 6 requirements
 - **Penalties** (Art 83): 1 requirement
-

A – Controller Instructions

A.1 Processing Instructions & Procedure Review

ISAE Requirement: Written procedures requiring documented controller instructions; annual assessments

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 1: Processing only on instructions from controller
 - Para 3(a): Documented instructions required
 - Para 3(b): Ensure processor doesn't process for own purposes
- **Art 5 - Principles** (Principles)
 - Para 2(d): Accountability principle (maintain records of instructions)



Secondary References:

- SOC 2: CC3.1, CC5.3, CC7.1 (objectives, policies, configuration changes)
- ISO 27001: A.5.1 (policies for information security)
- ISO 27701: A.2.2 (controller-processor relationship)

Evidence to Gather:

- Documented controller instruction procedures
 - Records of annual review of instructions
 - Evidence of compliance with Art 28(3)(a) written instructions requirement
 - Processing instructions registry/register
-

A.2 Compliance with Processing Agreements

ISAE Requirement: Data processor only processes per controller instructions; DPA alignment

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 1: Processing only on documented instructions
 - Para 3: Content of data processing agreement
- **Art 5 - Principles** (Principles)
 - Para 1(a): Lawfulness, fairness, transparency
 - Para 2(a): Accountability in processing activities
- **Art 6 - Lawfulness of processing** (Principles)
 - Instructions must be lawful

Secondary References:

- SOC 2: P5.1 (consistency of processing with objectives), CC2.1 (quality of information)
- ISO 27001: A.5.1 (policy documentation)

Evidence to Gather:

- Processing activities register (mapped to DPA instructions)
 - Sample data processing agreements
 - Activity/processing logs showing instruction compliance
 - Records demonstrating lawful processing basis
-



A.3 Reporting Potentially Unlawful Instructions

ISAE Requirement: Data processor assesses and reports instructions violating GDPR/EU law to controller

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Implied in processor obligation to ensure lawful processing
- **Art 32 - Security of processing** (Controller and processor)
 - Para 1: Processor responsible for security measures
 - Para 1(b): Ensuring only authorized access
- **Art 33 - Notification of breach** (Controller and processor)
 - Processor responsibility to notify controller

Secondary References:

- SOC 2: CC3.3 (fraud consideration), CC2.3 (external communication)
- ISO 27701: A.2.2 (processor obligations)
- NIS2 Directive: Incident escalation procedures

Evidence to Gather:

- Procedure for assessing lawfulness of instructions
 - Case records of unlawful instructions (if any) with controller notifications
 - Confirmation of zero unlawful cases (if none occurred)
 - Escalation procedure documentation
-

B – Technical and Physical Security Measures

B.1 Safeguards Implementation & Review

ISAE Requirement: Written procedures for implementing agreed safeguards; annual assessments

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1: Technical and organizational measures required
 - Para 2: Processor implements measures appropriate to risk
- **Art 28 - Data processor** (Controller and processor)
 - Para 3(c): Agreement on security measures
- **Art 30 - Records of processing activities** (Controller and processor)
 - Document security measures implemented

Secondary References:



- SOC 2: CC5.1, CC6.1c, CC4.1 (control activities, asset security, monitoring)
- ISO 27001: A.5, A.12 (organizational and operational controls)
- ISO 27017: A.2.1 (cloud-specific safeguards)

Evidence to Gather:

- Security measures implementation procedure (aligned to Art 32)
 - Evidence of latest procedure review
 - DPA Annex II security requirements
 - Implementation evidence (configurations, audit reports, screenshots)
-

B.2 Risk Assessment & Technical Measures

ISAE Requirement: Risk assessment performed; technical measures implemented based on risk assessment

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1: Measures appropriate to the risk
 - Para 2: Basis = risk assessment
- **Art 35 - Data protection impact assessment** (Controller and processor)
 - Risk assessment and evaluation of impacts
 - Required before high-risk processing

Secondary References:

- SOC 2: CC3.2, CC5.1, CC5.2 (risk identification, control activities)
- DORA: Risk assessment framework
- NIST CSF 2.0: Identify & Protect functions
- ISO 27001: A.12 (operational controls based on risk)

Evidence to Gather:

- Latest dated risk assessment (per Art 32)
 - Risk assessment methodology documentation
 - Risk approval by management
 - Evidence of technical measures implementation
 - DPA security requirements and mapping to risk assessment
-



B.3 Antivirus Protection & Updates

ISAE Requirement: Antivirus software installed and regularly updated on systems processing personal data

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(a): Pseudonymization and encryption
 - Para 1(b): Ability to restore availability and access
 - Para 2: Measures appropriate to risk
- **Art 28 - Data processor** (Controller and processor)
 - Processor ensures appropriate security level

Secondary References:

- SOC 2: CC6.1c, CC7.2 (technical security, system monitoring)
- CIS 18 Controls: Control 10 (malware defenses)
- ISO 27001: A.12.2 (malware protection)
- NIST CSF 2.0: Detect function

Evidence to Gather:

- Inventory of systems processing personal data
 - Antivirus/endpoint protection coverage report
 - Patch update status (last 90 days)
 - Update schedule or automated update evidence
-

B.4 Firewall Protection for External Access

ISAE Requirement: External access to systems protected through secured firewall

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(a): Encryption and pseudonymization
 - Para 1(b): Ability to ensure ongoing confidentiality, integrity, availability
 - Para 2: Appropriate to risk and nature of personal data
- **Art 28 - Data processor** (Controller and processor)
 - Ensure security measures in place

Secondary References:

- SOC 2: CC6.2, CC7.1 (logical access, configuration management)
- CIS 18 Controls: Control 1 (asset inventory)
- ISO 27001: A.13.1 (network security)



- NIST CSF 2.0: Protect function

Evidence to Gather:

- Network diagram showing external access routes and firewall placement
 - Current firewall configuration/rules export
 - Firewall configuration standard/policy
 - Evidence of firewall maintenance and updates
-

B.5 Network Segmentation

ISAE Requirement: Internal networks segmented to restrict access to systems processing personal data

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(b): Ability to ensure ongoing confidentiality and integrity
 - Para 2: Appropriate to risk
- **Art 5 - Principles** (Principles)
 - Para 1(f): Integrity and confidentiality

Secondary References:

- SOC 2: CC6.1a, CC6.2b (asset identification, logical access)
- CIS 18 Controls: Control 1, 3 (asset management, network architecture)
- ISO 27001: A.13.1 (network segregation)
- NIST CSF 2.0: Protect function

Evidence to Gather:

- Network segmentation diagram
 - VLAN/firewall configuration showing restricted access
 - List of permitted inter-segment connections
 - Evidence of segment maintenance/review
-

B.6 Access Control for Personal Data

ISAE Requirement: Access to personal data limited to users with work-related need; periodic review

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)



- Para 1(b): Ability to ensure confidentiality and integrity
- Para 2: Appropriate to risk and nature of processing
- **Art 28 - Data processor** (Controller and processor)
 - Ensure only authorized persons access personal data
- **Art 5 - Principles** (Principles)
 - Para 1(f): Integrity and confidentiality principle
 - Para 2(a): Accountability (demonstrate compliance)

Secondary References:

- SOC 2: CC6.2 (prior to issuing credentials, periodic review)
- ISO 27001: A.9 (access control)
- ISO 27701: A.3.1 (data processing limitation)

Evidence to Gather:

- Access control procedure with authorization process
- Access approval requirements and business justification documentation
- Current user access listing for systems with personal data
- Sample access approvals with business justifications
- Latest periodic access review records with change management
- Deactivation records for employees with access

B.7 System Monitoring & Alerts

ISAE Requirement: System monitoring established with alarm features; investigation and escalation

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(c): Ability to restore availability (implies incident detection)
 - Para 1(g): Regular testing of measures
 - Para 2: Appropriate to risk
- **Art 33 - Notification of breach** (Controller and processor)
 - Processor must detect and notify controller of breaches
- **Art 28 - Data processor** (Controller and processor)
 - Processor ensures security measures in place
- **Art 30 - Records of processing activities** (Controller and processor)
 - Document security measures (including monitoring)

Secondary References:

- SOC 2: CC7.2, CC7.3, CC7.4 (monitoring, security events evaluation)
- CIS 18 Controls: Control 8 (audit logging)
- ISO 27001: A.12.4 (event logging and monitoring)



- NIST CSF 2.0: Detect function

Evidence to Gather:

- Monitoring configuration and alert overview for systems with personal data
 - Alert rules and thresholds
 - Investigation procedure for detected events
 - Sample investigation records (3 selected alerts)
 - Controller notification records (if applicable)
-

B.8 Encryption for Internet/Email Transfers

ISAE Requirement: Effective encryption applied when transmitting sensitive/confidential personal data

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(a): Encryption of personal data
 - Para 1(b): Ability to ensure ongoing confidentiality
 - Para 2: Measures appropriate to risk and nature of data
- **Art 5 - Principles** (Principles)
 - Para 1(f): Integrity and confidentiality

Secondary References:

- SOC 2: CC6.1c, C1.2 (technical security, confidentiality protection)
- ISO 27001: A.10.1 (cryptography)
- ISO 27017: Cloud-specific encryption controls

Evidence to Gather:

- Procedure/user guidance for encrypted transfers
 - Configuration or screenshots of encryption technologies used
 - Redacted transfer example showing encryption
 - Overview of any unencrypted transfers (or confirmation none exist)
 - Encryption standard documentation
-

B.9 Logging of User & Security Events

ISAE Requirement: Logging of admin activities, security incidents, changes to logging, rights changes, failed logins

Primary GDPR References (Cyberday):



- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(g): Regular testing of measures (implies ongoing monitoring/logging)
 - Para 2: Appropriate to risk and processing type
- **Art 33 - Notification of breach** (Controller and processor)
 - Requires detection capability (logs support detection)
- **Art 28 - Data processor** (Controller and processor)
 - Document and maintain security measures
- **Art 30 - Records of processing activities** (Controller and processor)
 - Records of security measures

Secondary References:

- SOC 2: CC7.2, CC7.3, CC6.2c (monitoring, event evaluation, privileged access)
- CIS 18 Controls: Control 8 (audit logging)
- ISO 27001: A.12.4 (event logging, monitoring, protected logs)
- NIST CSF 2.0: Detect function

Evidence to Gather:

- Logging standard/policy covering:
 - Privileged user activities
 - Security event logging
 - Changes to logging configuration
 - Changes to user rights
 - Failed login attempts
- Current logging configuration for systems with personal data
- Representative redacted log extracts
- Log protection and retention settings documentation

B.10 Pseudonymization/Anonymization in Dev/Test

ISAE Requirement: Personal data in development/testing pseudonymized/anonymized or under documented controller agreement

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(a): Pseudonymization of personal data
 - Para 2: Appropriate to risk
- **Art 25 - Data protection by design and by default** (Controller and processor)
 - Implement technical and organizational measures (including pseudonymization)
 - Minimize personal data processing
- **Art 5 - Principles** (Principles)
 - Para 1(c): Data minimization



- Para 1(e): Storage limitation
- Para 1(f): Integrity and confidentiality

Secondary References:

- SOC 2: PI1.2 (system inputs)
- ISO 27701: Data minimization, pseudonymization
- ISO 27001: A.5 (organizational controls on data handling)

Evidence to Gather:

- Procedure for using personal data in development/testing environments
 - Inventory of development and test databases
 - Data extracts/configuration evidence for 3 selected databases showing:
 - Pseudonymization mechanism OR anonymization proof
 - Data minimization practices
 - If identifiable data used: documented controller agreement/instruction
 - For 3 databases: DPA/instructions and approval evidence
-

B.11 Vulnerability Scans & Penetration Testing

ISAE Requirement: Technical measures tested regularly through vulnerability scans and pen tests; weaknesses addressed

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(g): Regular testing of measures
 - Para 2: Appropriate to risk and nature of processing
- **Art 25 - Data protection by design and by default** (Controller and processor)
 - Implement technical measures (includes testing/validation)
- **Art 28 - Data processor** (Controller and processor)
 - Ensure appropriate security level

Secondary References:

- SOC 2: CC4.1, CC7.2 (control evaluation, system monitoring)
- CIS 18 Controls: Control 5 (vulnerability management)
- ISO 27001: A.14.2 (vulnerability management)
- NIST CSF 2.0: Identify, Detect functions

Evidence to Gather:

- Testing schedule (documented)
- Latest vulnerability scan report:
 - Scope defined



- Date performed
 - Internal or external testing noted
 - Findings documented
 - Latest penetration test report (same documentation)
 - Finding tracker/remediation log
 - Recent remediation or risk acceptance record
 - Controller communication (if relevant findings found)
-

B.12 Change & Patch Management

ISAE Requirement: System changes and patches controlled per procedure; includes security patches

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1: Ongoing security measures
 - Para 1(g): Regular testing (implies ongoing updates/changes)
 - Para 2: Appropriate to risk
- **Art 25 - Data protection by design and by default** (Controller and processor)
 - Implement technical measures
 - Keep measures up to date
- **Art 28 - Data processor** (Controller and processor)
 - Maintain security measures

Secondary References:

- SOC 2: CC8.1, CC7.1 (change management, configuration changes)
- CIS 18 Controls: Control 6 (asset management)
- ISO 27001: A.14.1 (information security change management)
- NIST CSF 2.0: Protect function

Evidence to Gather:

- Documented change and patch management procedure
 - Current patch-status report showing:
 - Systems with personal data
 - Patch application status
 - Critical/security patch coverage
 - Selected approved change tickets or deployment records
 - Evidence of patch testing before deployment
 - Patch schedule/automation evidence
-



B.13 User Access Management & Periodic Review

ISAE Requirement: Formalized procedure for granting/removing access; regular review with business need justification

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(b): Ability to ensure confidentiality and integrity
 - Para 2: Appropriate to risk
 - Ongoing management of access rights
- **Art 28 - Data processor** (Controller and processor)
 - Ensure only authorized persons access personal data
- **Art 5 - Principles** (Principles)
 - Para 1(f): Integrity and confidentiality
 - Para 2(a): Accountability (demonstrate compliance)

Secondary References:

- SOC 2: CC6.2, CC4.1, CC7.3 (access credentials, control evaluation, event removal)
- ISO 27001: A.9.2 (user access management)
- ISO 27701: A.3.1 (data processing limitation)

Evidence to Gather:

- Access management procedure covering:
 - Access authorization process
 - Periodic review requirements
 - Offboarding/deactivation
- Current user access listing for systems with personal data
- For 3 selected employees:
 - Access request/approval records
 - Business justification for access grant
 - Current assigned privileges
- Latest periodic access review (documented):
 - Review date
 - Participants
 - Results/changes made
- Employee departure/deactivation records (if applicable)

B.14 Two-Factor Authentication for High-Risk Processing

ISAE Requirement: Two-factor authentication required and active for high-risk systems/accounts

Primary GDPR References (Cyberday):



- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(b): Ability to ensure confidentiality and integrity
 - Para 2: Measures appropriate to risk (high-risk = stronger MFA)
- **Art 5 - Principles** (Principles)
 - Para 1(f): Integrity and confidentiality
- **Art 25 - Data protection by design** (Controller and processor)
 - Implement technical measures appropriate to risk

Secondary References:

- SOC 2: CC6.2, CC6.1c (multi-factor authentication for sensitive access)
- CIS 18 Controls: Control 2 (access control, MFA)
- ISO 27001: A.9.4 (privileged access rights)
- NIST CSF 2.0: Protect function

Evidence to Gather:

- Risk assessment identifying high-risk systems/accounts for personal data
- Procedure/policy requiring MFA for high-risk access
- System settings or screenshots showing MFA enforcement
- Configuration evidence for critical systems
- VPN/remote access guidance (if applicable)

B.15 Physical Access Safeguards

ISAE Requirement: Physical access controls restrict access to authorized persons only at premises/data centers with personal data

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1: Physical and technical measures
 - Para 1(b): Ability to ensure ongoing confidentiality and integrity
 - Para 2: Appropriate to risk and nature of processing
- **Art 5 - Principles** (Principles)
 - Para 1(f): Integrity and confidentiality
- **Art 28 - Data processor** (Controller and processor)
 - Ensure appropriate security level

Secondary References:

- SOC 2: CC6.1a, CC6.3 (asset identification, physical access)
- CIS 18 Controls: Control 1 (physical asset management)
- ISO 27001: A.11.1 (physical security perimeter)
- NIST CSF 2.0: Protect function



Evidence to Gather:

- Physical access procedure covering:
 - Badge/key issuance
 - Access authorization
 - Deactivation on departure
 - Current list of authorized persons
 - Latest access review (date, results)
 - Selected access record (audit trail)
 - Third-party facility control report (if data center is outsourced)
 - Visitor policy/log (if applicable)
-

C – Organisational Measures

C.1 Information Security Policy & Management Approval

ISAE Requirement: Written information security policy approved by management, communicated to stakeholders, based on risk assessment; annual review

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 2: Appropriate security measures based on risk
- **Art 25 - Data protection by design and by default** (Controller and processor)
 - Implement technical and organizational measures
 - Document security measures
- **Art 28 - Data processor** (Controller and processor)
 - Para 3: Data processing agreement must specify security measures
- **Art 30 - Records of processing activities** (Controller and processor)
 - Document security measures implemented

Secondary References:

- SOC 2: CC1.1, CC2.2, CC3.2 (management commitment, communication, risk-based)
- ISO 27001: A.5.1 (information security policies)
- ISO 27701: Policy development for privacy controls

Evidence to Gather:

- Current information security policy covering:
 - GDPR compliance requirements
 - Security measures and controls
 - Data processor responsibilities



- Dated management approval/review (within past 12 months)
 - Evidence of communication to staff:
 - Intranet screenshot
 - Distribution record
 - Acknowledgment log
 - Policy aligned to risk assessment
-

C.2 Policy Compliance with Data Processing Agreements

ISAE Requirement: Management verifies policy doesn't conflict with DPAs; policy covers security commitments in contracts

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 3(c): Agreement must specify technical and organizational measures
 - Para 4: Processor remains bound by GDPR even after contract ends
- **Art 32 - Security of processing** (Controller and processor)
 - Measures must align with controller agreements
- **Art 5 - Principles** (Principles)
 - Para 2(a): Accountability (demonstrate alignment)

Secondary References:

- SOC 2: CC2.1, CC5.2 (quality of information, control activities)
- ISO 27001: A.5.1 (policy integration)
- ISO 27701: A.2.2 (controller-processor agreement alignment)

Evidence to Gather:

- Management assessment/mapping document showing:
 - Policy requirements
 - DPA security clauses
 - Alignment evidence
 - For 3 selected DPAs:
 - Security clauses/Annex II
 - Evidence policy addresses each clause
 - Documentation of any gaps resolved
 - Approval by management
-

C.3 Employee Screening During Recruitment

ISAE Requirement: Employees screened per procedure during recruitment; includes references, criminal records, diplomas per DPA requirements



Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 3(c): Processor must ensure security level including personnel selection
 - Para 4: Processor bound by GDPR confidentiality
 - Implied: Personnel must be suitable/vetted
- **Art 5 - Principles** (Principles)
 - Para 2(a): Accountability (demonstrate suitable personnel)
- **Art 32 - Security of processing** (Controller and processor)
 - Para 1: Organizational measures including personnel selection

Secondary References:

- SOC 2: CC1.2, CC1.3 (board oversight, established responsibilities)
- ISO 27001: A.6.1 (personnel screening)
- ISO 27701: A.2.1 (employee selection and confidentiality)

Evidence to Gather:

- Employee screening procedure covering:
 - References checks
 - Criminal record verification (as required)
 - Qualifications/diplomas
- Overview of DPA screening requirements
- For 3 DPAs: mapping showing how procedure addresses requirements
- For 3 selected employees:
 - Redacted screening checklist
 - Date of screening
 - Outcome (passed/reference verified)
- If < 3 hires: all available with count noted

C.4 Employee Confidentiality & Information Security Induction

ISAE Requirement: Employees sign confidentiality agreements; receive induction on information security policy and data processing procedures

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 3: Persons must be bound by confidentiality
 - Para 4: Processor bound by GDPR confidentiality obligations
 - Persons authorized must understand GDPR
- **Art 29 - Processing under authority** (Controller and processor)
 - Persons authorized to process must commit to confidentiality
- **Art 5 - Principles** (Principles)



- Para 1(f): Integrity and confidentiality
- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(c): Ability to restore confidentiality and integrity

Secondary References:

- SOC 2: CC1.1, CC2.2 (management commitment, staff communication)
- ISO 27001: A.6.2 (information security awareness and training)
- ISO 27701: A.2.1 (employee confidentiality and awareness)

Evidence to Gather:

- Onboarding/induction procedure covering:
 - Confidentiality agreement requirement
 - Information security policy review
 - GDPR and data processing procedures
 - List of employees appointed
 - For 3 new hires:
 - Signed confidentiality agreement
 - Dated induction record with evidence of:
 - Policy acknowledgment
 - GDPR briefing
 - Processing procedures review
 - If < 3 hires: all available with count noted
-

C.5 Employee Offboarding: Access Removal & Asset Return

ISAE Requirement: Formalized process to ensure access deactivated/terminated upon departure; assets returned

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 3(g): Confidentiality obligations extend to termination
 - Implied: Access must be removed to maintain confidentiality
- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(b): Ability to ensure confidentiality and integrity
 - Para 2: Measures appropriate to risk
 - Requires removal of access on departure
- **Art 5 - Principles** (Principles)
 - Para 1(f): Confidentiality throughout employment and after

Secondary References:

- SOC 2: CC6.2, CC6.2c (access removal upon termination)
- ISO 27001: A.6.3 (return of assets)



- ISO 27701: A.2.1 (termination procedures)

Evidence to Gather:

- Offboarding procedure covering:
 - Access deactivation
 - System credential removal
 - Asset return process
 - Timeline for completion
 - List of employees who departed
 - For recent departing employee(s):
 - Completed offboarding checklist
 - Access deactivation ticket with date
 - Asset return confirmation (if applicable)
-

C.6 Continuation of Confidentiality Obligations Post-Departure

ISAE Requirement: Departing employees reminded confidentiality obligations continue after departure

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 3(g): Confidentiality obligations after termination
 - Para 4: Processor remains bound by confidentiality after contract ends
 - Persons must understand ongoing obligations
- **Art 29 - Processing under authority** (Controller and processor)
 - Authorization continues to bind persons after departure
- **Art 5 - Principles** (Principles)
 - Para 1(f): Confidentiality obligation is perpetual

Secondary References:

- SOC 2: CC1.1, CC2.3 (commitment, external communication)
- ISO 27001: A.6.2 (ongoing awareness)
- ISO 27701: A.2.1 (continuing confidentiality)

Evidence to Gather:

- Standard departure notice/exit interview documentation
 - Offboarding instruction covering continuing confidentiality
 - For recent departing employee:
 - Signed confidentiality agreement (original)
 - Dated reminder/acknowledgment of ongoing obligation
-



C.7 Security Awareness Training

ISAE Requirement: Regular security awareness training provided to employees on IT security and data processing security

Primary GDPR References (Cyberday):

- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(c): Ongoing confidentiality, integrity, availability
 - Para 2: Measures appropriate to risk include personnel awareness
 - Implied: Staff must understand security requirements
- **Art 28 - Data processor** (Controller and processor)
 - Para 3: Ensure appropriate security level
 - Personnel must understand data processing obligations
- **Art 5 - Principles** (Principles)
 - Para 1(f): Confidentiality - requires staff awareness
 - Para 2(a): Accountability (demonstrate staff competence)

Secondary References:

- SOC 2: CC1.1, CC2.2, PI2.2 (management commitment, staff communication, privacy training)
- ISO 27001: A.6.2 (information security awareness and training)
- CIS 18 Controls: Control 17 (security awareness and training)
- NIST CSF 2.0: Govern function

Evidence to Gather:

- Latest training material/curriculum covering:
 - General IT security
 - GDPR requirements
 - Personal data protection obligations
 - Date of material
 - Attendance/completion records for staff with personal data access:
 - Names of attendees
 - Dates of training
 - Topic coverage
 - Follow-up records for employees with missing training:
 - Rescheduled training dates
 - Completion records
-



D – Return and Deletion of Personal Data

D.1 Storage & Deletion Procedures & Annual Review

ISAE Requirement: Written procedures for storing and deleting personal data per controller agreement; annual review

Primary GDPR References (Cyberday):

- **Art 5 - Principles** (Principles)
 - Para 1(e): Storage limitation (only store as long as necessary)
 - Para 2(a): Accountability (document retention/deletion policy)
- **Art 17 - Right to erasure** (Data subject rights)
 - Para 3: Processor must delete data upon controller request
 - Implies: Deletion procedures required
- **Art 28 - Data processor** (Controller and processor)
 - Para 3(g): Delete or return data after processing ends
 - Para 3(e): Assist controller with deletion obligations
- **Art 30 - Records of processing activities** (Controller and processor)
 - Document deletion procedures and schedules

Secondary References:

- SOC 2: D1.1, D2.2 (data objectives, retention)
- ISO 27701: Data retention and deletion controls
- ISO 27001: A.8.3 (retention of information)

Evidence to Gather:

- Current storage and deletion procedure covering:
 - Storage location and duration
 - Retention periods by data category
 - Deletion process and triggers
 - Compliance with Art 5(1)(e)
 - Dated record of latest procedure review/update
 - Evidence of alignment with controller instructions
 - Evidence of implementation
-

D.2 Retention Periods & Deletion Routines per Agreement

ISAE Requirement: Retention periods and deletion routines defined in agreement; verified compliance for 2+ processing activities

Primary GDPR References (Cyberday):

- **Art 5 - Principles** (Principles)



- Para 1(e): Storage limitation (only necessary duration)
- Para 2(a): Accountability (demonstrate compliance)
- **Art 17 - Right to erasure** (Data subject rights)
 - Para 3: Processor must delete upon request per agreement
 - Processor must have deletion capability
- **Art 28 - Data processor** (Controller and processor)
 - Para 3(g): Deletion or return after processing
 - Agreement must specify retention periods
- **Art 6 - Lawfulness of processing** (Principles)
 - Retention period must align with lawful basis

Secondary References:

- SOC 2: D2.1, D2.2 (retention per objectives)
- ISO 27701: Retention and deletion controls
- NIST CSF 2.0: Govern function (data lifecycle)

Evidence to Gather:

- Controller instructions or DPA specifying:
 - Retention periods by data category
 - Deletion triggers
 - Lawful basis for retention
- Retention schedule document
- Deletion procedure
- For 2 selected processing activities:
 - System/database configuration showing storage period
 - Evidence data is not retained beyond agreed period
 - Records/reports of storage status
- For 2 selected processing activities:
 - Deletion logs/tickets showing completed deletion
 - Dates of deletion aligned to retention policy
 - Evidence of permanent deletion
- If < 2 available: all with count noted

D.3 Return or Deletion Upon Termination

ISAE Requirement: Data returned to controller and/or deleted per agreement upon processing termination; no unlawful retention

Primary GDPR References (Cyberday):

- **Art 17 - Right to erasure** (Data subject rights)
 - Para 3: Processor must delete data
 - Controller can request erasure
- **Art 28 - Data processor** (Controller and processor)



- Para 3(g): **Key requirement:** Upon termination of services:
 - Return personal data to controller, OR
 - Delete personal data (unless EU/member state law requires retention)
- **Art 5 - Principles** (Principles)
 - Para 1(e): Storage limitation (no retention after purpose ends)
 - Para 2(a): Accountability (document termination procedures)

Secondary References:

- SOC 2: D2.3 (removal of personal data)
- ISO 27701: Data return and destruction
- ISO 27001: A.8.3 (retention and disposal)

Evidence to Gather:

- Termination procedure covering:
 - Trigger events (contract end, data subject request)
 - Return process (delivery to controller)
 - Deletion process (confirmed destruction)
 - Lawful retention exceptions (if any)
 - Timeline for completion
 - Most recent terminated arrangement:
 - Related contract/DPA
 - Termination date
 - Return receipt OR deletion record
 - Evidence of lawful retention (if retained)
 - If no arrangements terminated: written confirmation
-

E – Storage and Processing Locations

E.1 Storage & Processing Procedure Aligned with DPA

ISAE Requirement: Written procedure requiring personal data stored per controller agreement; annual review; compliance verified for 3 activities

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 3(c): DPA must specify location and type of processing
 - Processor must only process per instructions
 - Location is part of controller's instructions
- **Art 5 - Principles** (Principles)
 - Para 1(a): Lawfulness (storage location per contract)
 - Para 2(a): Accountability (document storage location)
- **Art 30 - Records of processing activities** (Controller and processor)



- Document processing locations
- **Art 32 - Security of processing** (Controller and processor)
 - Para 2: Security measures appropriate to location/risk

Secondary References:

- SOC 2: D2.2, CC2.1 (processing consistency, information quality)
- ISO 27017: Cloud region and jurisdiction controls
- ISO 27001: A.8.1 (on-site and off-site storage)

Evidence to Gather:

- Storage and processing procedure covering:
 - Approved storage locations
 - Compliance with DPA requirements
 - Data residency requirements
 - Cloud vs on-premise
 - Dated evidence of latest procedure review
 - Overview of processing activities with locations
 - For 3 selected processing activities:
 - Relevant DPA/instructions specifying location
 - System configuration showing actual storage location
 - Data flow documentation showing storage path
 - Cloud region/data center documentation (if applicable)
-

E.2 Actual Processing/Storage Locations Match Approved Locations

ISAE Requirement: Actual processing/storage locations correspond to controller-approved locations; verified for 3 activities

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 3(c): Processing must follow controller instructions on location
 - Para 1: Processing only per instructions
 - Processor accountable for location compliance
- **Chapter V - Transfers to third countries** (Transfers of personal data)
 - Articles 44-49: If processing in third country, specific safeguards required
- **Art 5 - Principles** (Principles)
 - Para 1(a): Lawfulness (must comply with controller's location requirements)
 - Para 2(a): Accountability (demonstrate location compliance)
- **Art 6 - Lawfulness of processing** (Principles)
 - Location must be lawful (no unauthorized transfers)

Secondary References:



- SOC 2: D2.1, CC7.1 (retention per objectives, configuration monitoring)
- ISO 27017: Cloud region controls and compliance
- DORA: Geographical concentration of resources
- ISO 27701: Cross-border transfer controls

Evidence to Gather:

- Processing activity register or location inventory showing:
 - Each processing activity
 - Approved storage locations
 - Cloud regions (if applicable)
 - Service providers involved
 - For 3 selected processing activities:
 - DPA/controller approval specifying location
 - System configuration showing actual location:
 - Database server location
 - Cloud region (if AWS/Azure/GCP)
 - Data center location
 - Data flow documentation
 - Network configuration showing data routing
 - Current evidence of location compliance
 - Screenshots of cloud console (showing region)
 - Service provider certifications (data location)
 - Network diagrams
-

F – Use of Sub-Processors

F.1 Sub-Processor Appointment Procedure & Annual Review

ISAE Requirement: Written procedures for engaging sub-processors; includes DPA requirements; annual review

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 2: Processor must NOT engage sub-processor without:
 - Prior specific or general authorization from controller
 - Written contract imposing data protection obligations
 - Para 3(e): Agreement must specify authorization conditions
 - Processor accountable for sub-processor compliance
- **Art 30 - Records of processing activities** (Controller and processor)
 - Document sub-processor arrangements
- **Art 5 - Principles** (Principles)
 - Para 2(a): Accountability (document sub-processor governance)



Secondary References:

- SOC 2: CC5.3, CC9.2 (policy establishment, partner risk management)
- ISO 27001: A.14.2 (supplier relationships)
- ISO 27701: A.2.2 (sub-processor agreements)
- DORA: Third-party risk management

Evidence to Gather:

- Sub-processor appointment procedure covering:
 - Authorization process (specific vs. general)
 - Assessment criteria (security, reliability)
 - Contract/DPA requirements per Art 28(4)
 - Notification to controller per Art 28(2)(h)
 - Objection/change management process
 - DPA template for sub-processors ensuring Art 28(4) compliance
 - Dated record of latest procedure review/update
-

F.2 Sub-Processor Authorization & Register

ISAE Requirement: Only approved sub-processors used; verified authorizations for 2+ selected

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 2: Only use sub-processors with controller authorization:
 - Specific authorization for named sub-processors OR
 - General authorization for categories
 - Para 3(e): Authorization conditions in DPA
- **Art 30 - Records of processing activities** (Controller and processor)
 - Maintain register of sub-processors
- **Art 5 - Principles** (Principles)
 - Para 2(a): Accountability (maintain authorization records)

Secondary References:

- SOC 2: CC9.2, CC5.2 (partner management, authorized activities)
- ISO 27001: A.14.2 (supplier information management)

Evidence to Gather:

- Current sub-processor register containing:
 - Sub-processor name
 - Services provided
 - Affected controllers/processing activities



- Authorization status (specific or general)
 - Date of authorization
 - For 2 selected sub-processors:
 - Written DPA or controller approval:
 - Specific authorization (named sub-processor) OR
 - General authorization (category/country)
 - Evidence of controller acceptance/notification
 - Evidence of Art 28(4) obligations in contract
 - If < 2 sub-processors used: all available with evidence
-

F.3 Sub-Processor Change Notification & Approval

ISAE Requirement: Controllers notified/asked to approve changes to sub-processors; objection procedures in place

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 2(h): **Key requirement:** Processor must:
 - Inform controller of any intended changes concerning addition/replacement of sub-processor
 - Give controller opportunity to object (if general authorization)
 - Not use sub-processor if controller objects
 - Para 3(e): Conditions for authorization in DPA
- **Art 5 - Principles** (Principles)
 - Para 2(a): Accountability (document notifications)

Secondary References:

- SOC 2: CC2.3, CC9.2 (external communication, partner management)
- ISO 27001: A.14.2 (supplier relationship changes)
- ISO 27701: A.2.2 (sub-processor change notification)

Evidence to Gather:

- Sub-processor change procedure covering:
 - Process for notifying controller of changes
 - Advance notice period
 - Objection handling process
 - Timeline for implementation
- Log/register of sub-processor changes including:
 - Date of change (addition/removal)
 - Sub-processor name
 - Notification date to controller
 - Objection received? (Y/N)
 - Resolution



- For selected changes:
 - Dated controller notification (email, letter)
 - Objection records (if any) with resolutions
 - Evidence of non-use (if objection sustained)
 - Specific approval (if required per DPA)
 - If no changes: written confirmation and documentation of procedure
-

F.4 Data Protection Obligations Passed to Sub-Processors

ISAE Requirement: Sub-processor agreements impose same data protection obligations as in controller DPA; verified for 3+

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 4: **Key requirement:** Sub-processor agreement must:
 - Impose same data protection obligations on sub-processor
 - As are imposed on processor in controller agreement
 - In particular, authorization/instruction and confidentiality
 - Processor remains liable if sub-processor fails
- **Art 82 - Liability** (implied in Article 28(4))
 - Processor liable for sub-processor non-compliance
- **Art 30 - Records of processing activities** (Controller and processor)
 - Document sub-processor agreements

Secondary References:

- SOC 2: CC5.2, CC9.2 (control activities, partner obligations)
- ISO 27001: A.14.2 (supplier security requirements)
- ISO 27701: A.2.2 (sub-processor obligations)

Evidence to Gather:

- Sub-processor register (from F.2)
 - For 3 selected sub-processors:
 - Signed data processing agreement/contract
 - Mapping/comparison document showing:
 - Art 28 obligations from controller DPA
 - Corresponding obligations in sub-processor DPA
 - Confirmation of equivalent protections
 - Key clauses: authorization, confidentiality, security measures, deletion, audit rights
 - Evidence of adequate security level (Annex II equivalent)
 - Sub-processor DPA template (if not all negotiated)
-



F.5 Sub-Processor Register with Required Details

ISAE Requirement: Sub-processor register includes: name, business registration number, address, processing description

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 2: Processor must provide list of sub-processors to controller
 - Information must enable controller to exercise rights
- **Art 30 - Records of processing activities** (Controller and processor)
 - Maintain records of sub-processor details
- **Art 5 - Principles** (Principles)
 - Para 2(a): Accountability (maintain sub-processor information)

Secondary References:

- SOC 2: CC2.1, CC9.2 (information quality, vendor inventory)
- ISO 27001: A.14.2 (supplier inventory)

Evidence to Gather:

- Sub-processor register (from F.2) containing:
 - Sub-processor name
 - Business registration number
 - Registered address
 - Description of processing/services provided
 - Approval status (specific/general)
 - Date added/approved
 - Contact information (if applicable)
 - Register available to controllers upon request
 - Register updated when changes occur
-

F.6 Sub-Processor Risk Assessment & Monitoring

ISAE Requirement: Risk assessment for each sub-processor; regular monitoring (meetings, inspections, audits); controllers informed

Primary GDPR References (Cyberday):

- **Art 28 - Data processor** (Controller and processor)
 - Para 1: Processor responsible for sub-processor compliance
 - Para 3(c): DPA must include security measures (due diligence on sub-processor)
 - Processor must monitor sub-processor compliance
- **Art 5 - Principles** (Principles)



- Para 2(a): Accountability (demonstrate monitoring of sub-processor)
- **Art 32 - Security of processing** (Controller and processor)
 - Para 1: Appropriate security measures (extend to sub-processor)
 - Para 2: Appropriate to risk and nature of processing
- **Art 30 - Records of processing activities** (Controller and processor)
 - Document sub-processor monitoring

Secondary References:

- SOC 2: CC3.2, CC4.1, CC9.2 (risk identification, monitoring, partner management)
- DORA: Third-party risk assessment and monitoring
- ISO 27001: A.14.2 (monitoring supplier performance)
- NIST CSF 2.0: Identify, Assess functions

Evidence to Gather:

- Risk assessments for sub-processors covering:
 - Type of data processed
 - Volume of data
 - Security measures
 - Regulatory compliance
 - Incident history
 - Latest monitoring evidence (one or more):
 - ISAE 3000 report from sub-processor
 - SOC 2 Type II report
 - ISO 27001 certification
 - Audit report (internal or external)
 - Review meeting records (date, findings)
 - Inspection records (date, observations)
 - Findings/observations log showing:
 - Issues identified
 - Remediation actions
 - Timeline for correction
 - Verification of correction
 - Controller communication records:
 - Notifications of significant findings
 - Updates on remediation status
 - Proof of controller awareness
-

G – Transfers to Third Countries

G.1 Third-Country Transfer Procedure & Annual Review

ISAE Requirement: Written procedures for third-country transfers requiring documented controller instructions; uses valid transfer basis; annual review



Primary GDPR References (Cyberday):

- **Art 44 - General principle** (Transfers of personal data)
 - Personal data only transferred to third country if safeguards in Chapter V
 - Only per controller instructions
- **Art 45-49 - Transfer mechanisms** (Transfers of personal data)
 - Art 45: Adequacy decision from EU Commission
 - Art 46: Appropriate safeguards (SCC, BCR, etc.)
 - Art 49: Derogations for specific situations
- **Art 28 - Data processor** (Controller and processor)
 - Para 1: Only process per controller instructions
 - Processor responsible for lawful transfers
- **Art 5 - Principles** (Principles)
 - Para 1(a): Lawfulness (transfer must be lawful)
 - Para 2(a): Accountability (document transfer basis)

Secondary References:

- SOC 2: D2.1 (data retention per objectives, including location)
- ISO 27701: International data transfer controls
- ISO 27001: A.8.1 (storage in different locations)
- ISO 27017: Cross-border data transfer controls

Evidence to Gather:

- Third-country transfer procedure covering:
 - Identification of transfers
 - Assessment of transfer basis (Art 45/46/49)
 - Documentation requirements
 - Controller notification/authorization process
 - Compliance with Schrems II (if applicable)
 - Supplementary measures (if needed)
 - Procedure based on GDPR Chapter V requirements
 - Dated record of latest procedure review/update (within 12 months)
-

G.2 Transfers Follow Controller Instructions/Approvals

ISAE Requirement: Transfers only per documented controller approvals; register of third-country transfers; verified for 3+ transfers

Primary GDPR References (Cyberday):

- **Art 44 - General principle** (Transfers of personal data)
 - No transfer without Chapter V safeguards
 - Only per controller instructions



- **Art 28 - Data processor** (Controller and processor)
 - Para 1: Only process per controller instructions (includes transfers)
 - Processor accountable for lawful transfers
- **Art 5 - Principles** (Principles)
 - Para 2(a): Accountability (document approvals/instructions)

Secondary References:

- SOC 2: D2.2 (processing consistency with objectives)
- ISO 27701: Transfer authorization
- ISO 27017: Cross-border transfer approval

Evidence to Gather:

- Third-country transfer register containing:
 - Processing activity/data category
 - Recipient/country
 - Transfer date (or ongoing if continuous)
 - Affected controller(s)
 - Transfer basis used (Art 45/46/49)
 - Supplementary measures (if applicable)
- For 3 selected transfers:
 - Controller DPA or written approval:
 - Authorization for transfer to recipient/country
 - Specification of transfer basis
 - Transfer records/documentation:
 - Evidence transfer occurred as approved
 - Data transfer logs
 - Recipient confirmation
 - Compliance verification
- If < 3 transfers: all available with count noted
- If no third-country transfers: written confirmation

G.3 Transfer Mechanism & Supporting Assessment

ISAE Requirement: Each transfer has appropriate documented mechanism; assessment of validity; supplementary safeguards if needed

Primary GDPR References (Cyberday):

- **Art 45 - Adequacy decision** (Transfers of personal data)
 - Transfer if Commission has adopted adequacy decision for country
 - No other safeguards required
 - Examples: Canada, Japan, Uruguay (current)
- **Art 46 - Appropriate safeguards** (Transfers of personal data)
 - Transfer subject to appropriate safeguards including:



- Binding corporate rules
- Standard contractual clauses (SCCs)
- Approved codes of conduct
- Approved certifications
- **Art 49 - Derogations** (Transfers of personal data)
 - Limited exceptions when Chapter V doesn't apply:
 - Data subject consent
 - Contract with data subject
 - Public interest
 - Legal claim
 - Vital interests
 - (Others in Art 49)
- **Schrems II considerations** (if applicable):
 - Assessment of third-country legal framework
 - Supplementary measures needed
 - EU Standard Contractual Clauses (SCCs) with supplementary measures

Secondary References:

- SOC 2: CC3.2 (risk identification, including transfer risk)
- ISO 27701: Assessment of adequacy of safeguards
- ISO 27017: Transfer mechanism documentation
- DORA: Third-country operational resilience

Evidence to Gather:

- For 3 transfers (or all if fewer):
 - Transfer mechanism documentation:
 - **If Art 45:** Adequacy decision reference
 - **If Art 46:**
 - Standard Contractual Clauses (SCCs) signed
 - OR Binding Corporate Rules (BCRs)
 - OR Approved code of conduct/certification
 - With date and parties
 - **If Art 49:** Derogation basis documented
 - Data subject consent, OR
 - Contract with subject, OR
 - Other basis with explanation
 - Schrems II assessment (if using SCCs):
 - Analysis of third-country legal framework
 - Assessment of government access/surveillance
 - Supplementary measures documentation:
 - Encryption at rest
 - Pseudonymization
 - Technical controls
 - Contractual protections
 - Risk assessment justifying mechanism chosen
- Procedure for assessing transfer mechanisms (if not in G.1)



- Approval documentation
 - Evidence of data controller awareness/approval
-

H – Assistance with Data Subject Rights

H.1 Data Subject Rights Assistance Procedure & Annual Review

ISAE Requirement: Written procedures for processor to assist controller with data subject rights; annual review

Primary GDPR References (Cyberday):

- **Articles 12-23 - Data subject rights** (Data subject rights)
 - Art 12: Rights transparency and modalities
 - Art 13-14: Information to be provided
 - Art 15: Right of access
 - Art 16: Right to rectification
 - Art 17: Right to erasure
 - Art 18: Right to restriction
 - Art 19: Notification of rectification/erasure
 - Art 20: Right to data portability
 - Art 21: Right to object
 - Art 22: Automated decision-making
 - Art 23: Restrictions on rights
- **Art 28 - Data processor** (Controller and processor)
 - Para 3(e): DPA must specify processor assistance with rights requests
 - Processor must assist controller in fulfilling rights
- **Art 5 - Principles** (Principles)
 - Para 1(a): Transparency (in exercising rights)
 - Para 2(a): Accountability (document rights procedures)

Secondary References:

- SOC 2: P2.1, P3.1 (choice communication, scope consistency)
- ISO 27701: Data subject rights support processes
- ISO 27001: A.5.1 (information security policies)

Evidence to Gather:

- Procedure for data subject rights assistance covering:
 - Types of requests (access, deletion, correction, etc.)
 - Receiving requests from controller
 - Timeframe for assistance
 - Methods of assistance (system access, data extracts, etc.)
 - Documentation/logging of requests



- Escalation for complex requests
 - Regular review mechanism
 - Dated record of latest procedure review/update (within 12 months)
 - Evidence of alignment with Art 28(3)(e) DPA requirements
-

H.2 Capability to Assist with All Agreed Rights

ISAE Requirement: Procedures enable timely assistance for access, correction, deletion, restriction, information requests as agreed

Primary GDPR References (Cyberday):

- **Art 15 - Right of access** (Data subject rights)
 - Processor must assist controller to provide data subject copy
 - Information about processing
- **Art 16 - Right to rectification** (Data subject rights)
 - Processor must assist with correcting inaccurate data
 - Demonstrate correction made
- **Art 17 - Right to erasure** (Data subject rights)
 - Processor must assist controller with deletion
 - Confirm deletion to controller
- **Art 18 - Right to restriction** (Data subject rights)
 - Processor must restrict processing per instruction
 - Document restriction
- **Art 20 - Right to data portability** (Data subject rights)
 - Processor must assist in providing data in machine-readable form
- **Art 21 - Right to object** (Data subject rights)
 - Processor must assist with handling objections
 - Restrict processing upon objection
- **Art 28 - Data processor** (Controller and processor)
 - Para 3(e): DPA specifies which rights processor assists with

Secondary References:

- SOC 2: P2.1, P3.1, P4.1, P4.2 (choice, scope, requests, data deletion)
- ISO 27701: Individual rights management
- ISO 27001: A.5.1 (policies for fulfilling rights)

Evidence to Gather:

- Work instructions/procedures for each right:
 - **Access requests:** System query, data extract, format (PDF/CSV)
 - **Rectification:** Correction form, approval, update process
 - **Deletion:** Data purge process, confirmation of deletion
 - **Restriction:** Flagging/blocking, process to remove restriction
 - **Portability:** Export formats, delivery method



- **Objection:** Processing stop, retention policy
 - System documentation or redacted demonstration showing:
 - User interface for rights requests
 - Automated/manual processing
 - Timestamping of requests
 - Audit trail of actions
 - Request log showing:
 - Date received
 - Right type
 - Requester (controller/subject)
 - Resolution time
 - Completion status
 - Completed request example (redacted):
 - Request details
 - Processor response
 - Data provided/action taken
 - Timeline
 - Controller notification
 - If no requests received: confirmation of procedure readiness
-

I – Personal Data Breach Management

I.1 Breach Notification Procedure & Annual Review

ISAE Requirement: Written procedure for processor to inform controller of breaches without undue delay; annual review

Primary GDPR References (Cyberday):

- **Art 33 - Notification to supervisory authority** (Controller and processor)
 - Controller responsible for notifying authority within 72 hours
 - **Processor must notify controller without undue delay**
 - Implied: Processor needs breach detection and notification procedure
- **Art 34 - Communication to data subject** (Controller and processor)
 - Controller notifies subject if high risk
 - Processor assists controller
- **Art 28 - Data processor** (Controller and processor)
 - Para 3(f): DPA must specify processor obligation to notify controller of breach
 - Processor responsible for breach notification process
- **Art 5 - Principles** (Principles)
 - Para 2(a): Accountability (document breach procedures)
- **Art 30 - Records of processing activities** (Controller and processor)
 - Document breach management procedures

Secondary References:



- SOC 2: C1.2, CC7.3, CC2.3 (confidentiality disposal, security events, external communication)
- ISO 27001: A.17.1 (incident management procedure)
- ISO 27701: Breach notification procedure
- NIS2 Directive: Incident notification timelines

Evidence to Gather:

- Breach response procedure covering:
 - Definition of personal data breach (per Art 4(12))
 - Detection mechanisms
 - Assessment of risk to rights/freedoms
 - Documentation of facts
 - Notification decision process
 - Content of controller notification
 - Timeframe (without undue delay, no later than Art 33 requires)
 - Escalation process
 - Sub-processor notification (if applicable)
 - Data processing agreement (Annex) specifying:
 - Processor notification obligation
 - Notification timing
 - Content of notification
 - Dated record of latest review/approval (within 12 months)
-

I.2 Breach Identification Controls: Awareness, Monitoring, Log Review

ISAE Requirement: Controls to identify breaches: staff awareness, network monitoring, access-log review

Primary GDPR References (Cyberday):

- **Art 33 - Notification of breach** (Controller and processor)
 - Processor must identify breaches to notify controller
 - Implies: Detection capability required
- **Art 32 - Security of processing** (Controller and processor)
 - Para 1(c): Ability to restore availability and access (implies breach detection)
 - Para 1(g): Testing of security measures (includes monitoring)
 - Para 2: Appropriate to risk
- **Art 5 - Principles** (Principles)
 - Para 1(f): Integrity and confidentiality (monitoring supports this)
 - Para 2(a): Accountability (demonstrate breach detection)

Secondary References:

- SOC 2: CC7.2, CC7.3, CC2.2 (monitoring, event evaluation, staff communication)



- CIS 18 Controls: Control 8 (audit logging), Control 17 (awareness)
- ISO 27001: A.12.4 (event logging), A.6.2 (awareness training)
- NIST CSF 2.0: Detect function

Evidence to Gather:

- **Staff Awareness:**
 - Latest training material on breach recognition (can reuse from C.7):
 - Definition of personal data breach
 - Examples (unauthorized access, loss, modification, etc.)
 - Reporting procedure
 - Escalation contacts
 - Training records for relevant staff
 - **Network Monitoring:**
 - Network monitoring/SIEM configuration
 - Alert rules for suspicious activity
 - Documentation of tools used (IDS/IPS, firewall, etc.)
 - Alert review procedure
 - **Access Log Review:**
 - Access logging configuration
 - Log retention policy
 - Log review procedure:
 - Frequency (daily, weekly, etc.)
 - Who reviews
 - Analysis methodology
 - Escalation criteria
 - Recent redacted investigation example:
 - Alert/log entry
 - Analysis performed
 - Conclusion (breach vs false positive)
 - Timeline
-

I.3 24-Hour Notification to Controller

ISAE Requirement: Breaches notified to controller within 24 hours of processor awareness; includes sub-processor breaches

Primary GDPR References (Cyberday):

- **Art 33 - Notification of breach** (Controller and processor)
 - Para 1: Controller must notify supervisory authority within **72 hours** (GDPR requirement)
 - BUT processor must notify controller **without undue delay** and in any case **no later than controller notification to authority**
 - In practice: processor typically has **24 hours** to notify controller
- **Art 28 - Data processor** (Controller and processor)



- Para 3(f): DPA specifies notification timeline (typically 24 hours)
- Processor accountable for timely notification
- **Art 5 - Principles** (Principles)
 - Para 2(a): Accountability (demonstrate timely notification)

Secondary References:

- SOC 2: CC7.3, CC2.3 (security events, external communication)
- ISO 27001: A.17.1 (incident response timelines)
- ISO 27701: Timely breach notification
- NIS2 Directive: 24-hour notification to authority

Evidence to Gather:

- Incident and breach register containing:
 - Breach ID
 - Detection date/time
 - Discovery method (monitoring, staff report, law enforcement, etc.)
 - Description of breach
 - Data categories affected
 - Approximate number of subjects
 - Severity assessment
 - Risk to rights/freedoms
 - Processor awareness time
 - Controller notification date/time
 - Time elapsed (should be ≤ 24 hours)
 - Sub-processor involvement (if any)
 - Status (contained, under investigation, resolved)
- For actual breach(es):
 - Case file for selected breach showing:
 - Initial detection/awareness (timestamp)
 - Investigation findings
 - Scope of breach
 - Root cause
 - Sub-processor notification (if applicable, with timestamps)
 - Dated notification to controller:
 - Email or formal letter
 - Content per Art 28(3)(f) DPA
 - Timestamp (within 24 hours of awareness)
 - Initial response actions taken
 - Timeline of investigation
 - Final report to controller
 - Evidence of escalation to leadership/incident management
 - Evidence of sub-processor notification (if multi-processor breach)
- If no breaches occurred: written confirmation in register



I.4 Assistance with Reports to Danish Data Protection Authority

ISAE Requirement: Procedure for assisting controller with notifications to Danish DPA;
cover: breach nature, consequences, measures taken/proposed

Primary GDPR References (Cyberday):

- **Art 33 - Notification to supervisory authority** (Controller and processor)
 - Para 3: Notification to supervisory authority must include:
 - Name and contact of data protection officer (if appointed)
 - Description of personal data breach
 - Likely consequences for natural persons
 - Measures taken or proposed to address breach and mitigate harm
 - Para 4: Processor must cooperate with controller and authority
- **Art 34 - Communication to data subject** (Controller and processor)
 - If high risk, controller communicates to subjects
 - Processor assists controller
- **Art 28 - Data processor** (Controller and processor)
 - Para 3(f): DPA specifies processor assistance with breach reporting
 - Processor must provide information controller needs for notification
- **Art 30 - Records of processing activities** (Controller and processor)
 - Document breach response and reporting

Secondary References:

- SOC 2: CC2.3, CC7.3 (external communication, event documentation)
- ISO 27001: A.17.1 (incident documentation and reporting)
- ISO 27701: Breach reporting to authorities

Evidence to Gather:

- Breach response procedure or reporting template containing:
 - Breach description elements:
 - Type of breach (unauthorized access, loss, modification, etc.)
 - Data categories affected
 - Number of subjects (estimated/confirmed)
 - Likely consequences:
 - Physical harm risk
 - Psychological harm
 - Financial harm
 - Discrimination risk
 - Other impacts
 - Measures taken or proposed:
 - Immediate containment actions
 - Mitigation measures
 - Communication plan to subjects
 - Long-term preventive measures
 - Processor assistance requirements:



- Information processor will provide to controller
- Timeline for providing information
- Coordination/communication channel
- For relevant breach(es):
 - Documentation processor provided to controller:
 - Breach investigation report
 - Risk assessment (consequence analysis)
 - Proposed measures/remediations
 - Evidence of controller DPA notification submission
 - Response/acknowledgment from Danish DPA (if received)
 - Subject notification records (if high risk)
 - Remediation tracking
- If no breaches occurred: procedure documentation demonstrating readiness

Cyberday Framework Summary

Primary GDPR References Used:

GDPR Section	Articles	ISAE Controls Mapped
Principles	Art 5-11	All controls (accountability basis)
Controller & Processor	Art 24-39	A.1-A.3, B.1-B.15, C.1-C.7, D.1-D.3, E.1-E.2, F.1-F.6, H.1-H.2, I.1-I.4
Data Subject Rights	Art 12-23	H.1, H.2
Transfers	Art 44-49	G.1, G.2, G.3
Liability	Art 83	Throughout (accountability)

Secondary Cyberday Frameworks:

- SOC 2: Supporting implementation controls
- ISO 27001 (2022): Security management system controls
- ISO 27017: Cloud-specific security
- ISO 27701: Privacy-specific controls
- DORA: Operational resilience (third-party risk)
- NIS2 Directive: Incident notification
- NIST CSF 2.0: Risk assessment framework
- CIS 18 Controls: Foundational controls
- Cyber Essentials: Basic cyber hygiene



Next Steps

1. **Load Mapping into Cyberday:** Reference this mapping for each ISAE 3000 control
 2. **Align Cyberday Tasks:** Ensure Cyberday tasks are created for each GDPR article requirement
 3. **Evidence Collection:** Use GDPR articles as primary search filters in Cyberday
 4. **Compliance Tracking:** Monitor completion of GDPR Article requirements per control
 5. **Audit Preparation:** Prepare evidence package organized by:
 - GDPR Article (primary)
 - ISAE Control Number (secondary)
 - SOC 2/ISO 27001 (supplementary verification)
-

Document Version: 1.0 GDPR-Primary

Last Updated: 2026-10-02

Next Review: 2027-10-02



Appendix B: ISO 27001:2022 to ISAE Control Mapping

ISO 27001:2022 to ISAE 3000 Control Mapping

Prepared for: Elumi

Framework: ISAE 3000 Type 1 Audit for ISO 27001:2022 Compliance

Primary Reference: ISO 27001:2022 (116 Controls across 15 categories)

Secondary Framework: SOC 2, GDPR, NIST CSF

Date: 2026-10-02

Overview: ISO 27001:2022 Coverage

ISO 27001:2022 defines **116 information security management controls** across **15 major categories**:

1. **Governance (8)** - Policies, roles, segregation of duties
 2. **Asset Management (7)** - Inventory, acceptable use, return of assets
 3. **Access Management (8)** - Access control, identity, authentication
 4. **Supplier Relationships (6)** - Supplier agreements, supply chain
 5. **Information Protection (7)** - Classification, labeling, privacy
 6. **Physical Security (12)** - Perimeters, entry, facilities, equipment
 7. **Legal & Compliance (6)** - Requirements, IP rights, records
 8. **Human Resource Security (7)** - Screening, training, responsibilities
 9. **Threat & Vulnerability Management (2)** - Threat intelligence, vulnerability mgmt
 10. **System & Network Security (6)** - Malware protection, networks
 11. **Secure Configuration (4)** - Configuration management, privileged utilities
 12. **Application Security (7)** - SDLC, requirements, architecture
 13. **Information Security Event Management (8)** - Assessment, response, learning
 14. **Continuity Management (5)** - Disruption, readiness, capacity
 15. **Section 4: Foundation (23)** - Organization, context, scope, planning
-

Alignment Model

ISO 27001:2022 provides the detailed security controls framework.

ISAE 3000 defines audit requirements for data processors.

Mapping approach: Each ISO control → Related ISAE control(s) → Supporting evidence.



CATEGORY 1: GOVERNANCE (8 Controls)

ISO 27001 A.5.1 - Policies for Information Security

ISAE Control: C.1 - Info Security Policy & Approval

Alignment: HIGH

Requirement:

- Policies for information security established, documented, and communicated
- Policies reviewed and updated regularly
- ISAE requires: Documented policy, management approval, annual review

ISO 27001 A.5.2 - Information Security Roles and Responsibilities

ISAE Control: C.1, C.3

Alignment: HIGH

Requirement:

- Security roles assigned and responsibilities defined
- Communication of roles to relevant staff
- ISAE requires: Organizational responsibility structure, screening requirements

ISO 27001 A.5.3 - Segregation of Duties

ISAE Control: B.6, B.13

Alignment: MEDIUM

Requirement:

- Segregation of duties defined to prevent conflicts
- Implemented through role separation
- ISAE requires: Access control with business justification

ISO 27001 A.5.4 - Management Responsibilities

ISAE Control: C.1

Alignment: HIGH

Requirement:

- Management accountability for information security
- Resource allocation for security
- ISAE requires: Management approval of policies

ISO 27001 A.5.5 - Contact with Authorities

ISAE Control: I.1, I.4

Alignment: MEDIUM

Requirement:

- Contact information maintained for authorities



- Cooperation with regulatory bodies
- ISAE requires: Breach notification procedures (Art 31 gap)

ISO 27001 A.5.6 - Contact with Special Interest Groups

ISAE Control: —

Alignment: LOW/NOT COVERED

Requirement:

- Engagement with industry groups, security research
- ISAE scope: Not processor operational control

ISO 27001 A.5.7 - Threat Intelligence

ISAE Control: B.11

Alignment: MEDIUM

Requirement:

- Use threat intelligence for security measures
- Vulnerability management based on threats
- ISAE requires: Vulnerability scanning and pen testing

ISO 27001 A.5.8 - Use of Cryptography

ISAE Control: B.8

Alignment: HIGH

Requirement:

- Cryptographic controls for confidentiality/integrity
- Encryption for sensitive data
- ISAE requires: Encryption for internet/email transfers

CATEGORY 2: ASSET MANAGEMENT (7 Controls)

ISO 27001 A.5.9 - Inventory of Information and Other Associated Assets

ISAE Control: B.3, B.7

Alignment: HIGH

Requirement:

- Inventory of information assets
- Record of storage locations and systems
- ISAE requires: Inventory of systems processing personal data



ISO 27001 A.5.10 - Acceptable Use of Information and Other Associated Assets

ISAE Control: B.10

Alignment: MEDIUM

Requirement:

- Rules for appropriate use of assets
- Enforcement of acceptable use policy
- ISAE requires: Pseudonymization in dev/test environments

ISO 27001 A.5.11 - Return of Assets

ISAE Control: C.5

Alignment: HIGH

Requirement:

- Procedures for asset return on departure
- Verification of return
- ISAE requires: Employee offboarding with asset return

ISO 27001 A.5.12 - Classification of Information

ISAE Control: A.1, E.1

Alignment: MEDIUM

Requirement:

- Information classified by protection needs
- Classification guide and criteria
- ISAE requires: Processing activity classification

ISO 27001 A.5.13 - Labelling of Information

ISAE Control: —

Alignment: LOW/NOT COVERED

Requirement:

- Labels indicating information classification
- ISAE scope: Not specific procedural requirement

ISO 27001 A.5.34 - Privacy and Protection of PII

ISAE Control: All controls (privacy principle)

Alignment: HIGH

Requirement:

- Privacy requirements met
- Data subject rights supported
- ISAE requires: All controls aligned with privacy



CATEGORY 3: ACCESS MANAGEMENT (8 Controls)

ISO 27001 A.5.15 - Access Control

ISAE Control: B.6, B.13, B.14

Alignment: HIGH

Requirement:

- Access granted based on need
- Least privilege principle
- MFA for high-risk access
- Periodic access review

ISO 27001 A.5.16 - Identity Management

ISAE Control: B.6, C.4

Alignment: HIGH

Requirement:

- User identity uniquely identified
- Identity provisioning/deprovisioning
- Onboarding and offboarding procedures

ISO 27001 A.5.17 - Authentication Information

ISAE Control: B.14

Alignment: HIGH

Requirement:

- Strong authentication credentials
- Two-factor authentication for sensitive access
- Password management

ISO 27001 A.5.18 - Rights of Access

ISAE Control: H.2

Alignment: HIGH

Requirement:

- User rights defined and documented
- Access rights appropriate to role
- Support for data subject access rights



ISO 27001 A.5.19 - Information Security in Supplier Relationships

ISAE Control: F.1, F.2, F.6

Alignment: HIGH

Requirement:

- Security requirements in supplier contracts
- Supplier risk assessment
- Ongoing supplier monitoring

ISO 27001 A.5.20 - Addressing Information Security Within Supplier Agreements

ISAE Control: F.4

Alignment: HIGH

Requirement:

- Security clauses in supplier agreements
- Obligations equivalent to organization's
- SLA and remediation procedures

ISO 27001 A.5.21 - Managing Information Security in the ICT Supply Chain

ISAE Control: F.2, F.3

Alignment: HIGH

Requirement:

- Sub-processor authorization and monitoring
- Change notification for supply chain changes
- Documented sub-processor agreements

ISO 27001 A.5.22 - Monitoring, Review and Change Management of Supplier Services

ISAE Control: F.6

Alignment: HIGH

Requirement:

- Regular monitoring of supplier performance
- Risk assessment of suppliers
- Review and remediation of issues



CATEGORY 4: INFORMATION PROTECTION (7 Controls)

ISO 27001 A.5.23 - Information Security for Use of Cloud Services

ISAE Control: E.1, E.2

Alignment: HIGH

Requirement:

- Cloud service assessment before use
- Data location and residency requirements
- Processor responsibilities in cloud

ISO 27001 A.5.24 - Planning and Preparing for Information Security Incident Handling

ISAE Control: I.1, I.2

Alignment: HIGH

Requirement:

- Incident response plan
- Roles and responsibilities
- Detection and escalation procedures

ISO 27001 A.5.25 - Assessment and Decision on Information Security Events

ISAE Control: I.2, I.3

Alignment: HIGH

Requirement:

- Assessment of security events
- Classification of incidents
- Decision to report or escalate

ISO 27001 A.5.26 - Response to Information Security Incidents

ISAE Control: I.1, I.3

Alignment: HIGH

Requirement:

- Incident response actions
- Containment and remediation
- Timely notification (24-hour requirement)



ISO 27001 A.5.27 - Learning from Information Security Incidents

ISAE Control: I.1, I.4

Alignment: MEDIUM

Requirement:

- Post-incident review and learning
- Preventive measures based on lessons
- Communication of learnings

ISO 27001 A.8.1 - User Endpoint Devices

ISAE Control: B.3, B.7

Alignment: MEDIUM

Requirement:

- Protection of endpoint devices
- Malware protection and monitoring
- Inventory and configuration control

ISO 27001 A.8.2 - User Authentication for External Connections

ISAE Control: B.14

Alignment: HIGH

Requirement:

- Strong authentication for remote access
- MFA requirement
- Secure VPN/remote access protocols

CATEGORY 5: PHYSICAL SECURITY (12 Controls)

ISO 27001 A.7.1 - Physical Security Perimeters

ISAE Control: B.15

Alignment: HIGH

Requirement:

- Physical security perimeter for facilities
- Barriers and fencing
- Access control at perimeter

ISO 27001 A.7.2 - Physical Entry

ISAE Control: B.15

Alignment: HIGH

Requirement:



- Authorization required for physical access
- Visitor management procedures
- Badge and key control

ISO 27001 A.7.3 - Securing Offices, Rooms and Facilities

ISAE Control: B.15

Alignment: HIGH

Requirement:

- Physical protection of equipment
- Secure storage of assets
- Environmental controls (power, cooling)

ISO 27001 A.7.4 - Physical Security Monitoring

ISAE Control: B.7, B.15

Alignment: HIGH

Requirement:

- CCTV monitoring
- Intrusion detection
- Audit trails of physical access

ISO 27001 A.7.5 - Protecting Against Physical and Environmental Threats

ISAE Control: B.15

Alignment: MEDIUM

Requirement:

- Protection from fire, flood, earthquake
- Environmental hazard mitigation
- Business continuity planning

ISO 27001 A.7.6 - Working in Secure Areas

ISAE Control: B.15

Alignment: LOW/NOT COVERED

Requirement:

- Clean desk policy
- Visitor escort requirements
- ISAE scope: General practice, not specific control



ISO 27001 A.7.7 - Delivery and Loading Areas

ISAE Control: B.15

Alignment: MEDIUM

Requirement:

- Segregation of delivery areas from secure areas
- Control of incoming/outgoing materials
- Inspection procedures

ISO 27001 A.8.3 - Managing Removable Media

ISAE Control: B.8, B.9

Alignment: MEDIUM

Requirement:

- Procedures for removable media use
- Encryption of removable media
- Audit and tracking of media

ISO 27001 A.8.4 - Utility Supply

ISAE Control: B.1, E.1

Alignment: MEDIUM

Requirement:

- Redundant power supplies
- Backup power for critical systems
- Environmental monitoring

ISO 27001 A.8.5 - Cabling Security

ISAE Control: B.4, B.5

Alignment: MEDIUM

Requirement:

- Protection of data cables
- Segregation from power cables
- Cable management practices

ISO 27001 A.8.6 - Acquisition, Installation, Replacement and Removal of Equipment

ISAE Control: B.12, B.15

Alignment: MEDIUM

Requirement:

- Equipment lifecycle management
- Installation control



- Secure removal of equipment
 - Data sanitization before disposal
-

CATEGORY 6: LEGAL & COMPLIANCE (6 Controls)

ISO 27001 A.5.31 - Legal, Statutory, Regulatory and Contractual Requirements

ISAE Control: A.1, A.2

Alignment: HIGH

Requirement:

- Identification of legal requirements
- Compliance monitoring
- Documentation of requirements alignment

ISO 27001 A.5.32 - Intellectual Property Rights

ISAE Control: —

Alignment: LOW/NOT COVERED

Requirement:

- Protection of organization's IP
- ISAE scope: Not processor operational control

ISO 27001 A.5.33 - Protection of Records

ISAE Control: D.1, D.2

Alignment: HIGH

Requirement:

- Retention of records
 - Protection from damage/loss
 - Secure destruction
-

CATEGORY 7: HUMAN RESOURCE SECURITY (7 Controls)

ISO 27001 A.6.1 - Screening

ISAE Control: C.3

Alignment: HIGH

Requirement:



- Background screening before employment
- Reference checks
- Criminal record verification

ISO 27001 A.6.2 - Terms and Conditions of Employment

ISAE Control: C.4

Alignment: HIGH

Requirement:

- Security responsibilities in employment terms
- Confidentiality agreements
- Acceptable use policies

ISO 27001 A.6.3 - Information Security Awareness, Education and Training

ISAE Control: C.7

Alignment: HIGH

Requirement:

- Regular security awareness training
- Training on policies and procedures
- Record of training completion

ISO 27001 A.6.4 - Disciplinary Process

ISAE Control: —

Alignment: LOW/NOT COVERED

Requirement:

- Procedures for security violations
- ISAE scope: Organizational policy, not operational control

ISO 27001 A.6.5 - Responsibilities after Termination or Change of Employment

ISAE Control: C.5, C.6

Alignment: HIGH

Requirement:

- Access removal on departure
- Continuation of confidentiality obligations
- Return of assets



ISO 27001 A.6.6 - Confidentiality or Non-Disclosure Agreements

ISAE Control: C.4, C.6

Alignment: HIGH

Requirement:

- Signed confidentiality agreements
- Coverage of post-employment obligations
- Enforcement mechanisms

ISO 27001 A.6.7 - Remote Working

ISAE Control: B.4, B.8, B.14

Alignment: MEDIUM

Requirement:

- Security for remote workers
- VPN requirements
- MFA for remote access

CATEGORY 8: SYSTEM & NETWORK SECURITY (6 Controls)

ISO 27001 A.8.7 - Protection Against Malware

ISAE Control: B.3

Alignment: HIGH

Requirement:

- Antivirus/anti-malware software
- Regular updates
- Malware detection and response

ISO 27001 A.8.20 - Networks Security

ISAE Control: B.4, B.5

Alignment: HIGH

Requirement:

- Firewall protection
- Network segmentation
- Intrusion detection/prevention

ISO 27001 A.8.21 - Security of Network Services

ISAE Control: B.4, B.8

Alignment: MEDIUM

Requirement:



- Security parameters in network services
- Encrypted communications
- Service availability protection

ISO 27001 A.8.22 - Segregation of Networks

ISAE Control: B.5

Alignment: HIGH

Requirement:

- Network segmentation
- Isolation of sensitive networks
- VLANs and separate segments

ISO 27001 A.8.23 - Web Filtering

ISAE Control: —

Alignment: LOW/NOT COVERED

Requirement:

- Control of web access
- ISAE scope: General practice, not specific control

ISO 27001 A.8.29 - Information Systems Resilience and Redundancy

ISAE Control: B.1

Alignment: MEDIUM

Requirement:

- Redundancy for critical systems
- Failover capabilities
- Business continuity

CATEGORY 9: SECURE CONFIGURATION (4 Controls)

ISO 27001 A.8.9 - Configuration Management

ISAE Control: B.12

Alignment: HIGH

Requirement:

- Documented baselines
- Change control process
- Configuration tracking



ISO 27001 A.8.10 - Information Deletion

ISAE Control: D.1, D.3

Alignment: HIGH

Requirement:

- Secure data deletion procedures
- Confirmation of deletion
- Proper disposal of media

ISO 27001 A.8.18 - Use of Privileged Utility Programs

ISAE Control: B.13, B.14

Alignment: HIGH

Requirement:

- Restriction of privileged utilities
- Logging of privileged access
- Audit of utility use

ISO 27001 A.8.19 - Installation of Software on Operational Systems

ISAE Control: B.12

Alignment: HIGH

Requirement:

- Software installation controls
- Approval requirements
- Configuration management

CATEGORY 10: APPLICATION SECURITY (7 Controls)

ISO 27001 A.8.25 - Secure Development Life Cycle

ISAE Control: B.10

Alignment: MEDIUM

Requirement:

- Security in development process
- Design review
- Testing before deployment

ISO 27001 A.8.26 - Application Security Requirements

ISAE Control: B.10

Alignment: MEDIUM

Requirement:



- Security requirements in application design
- Input validation
- Output encoding

ISO 27001 A.8.27 - Secure System Architecture and Engineering Principles

ISAE Control: B.1

Alignment: MEDIUM

Requirement:

- Secure design principles
- Least privilege in application design
- Separation of concerns

ISO 27001 A.8.28 - Secure Coding

ISAE Control: B.10

Alignment: MEDIUM

Requirement:

- Coding standards for security
- Code review processes
- Vulnerability prevention

ISO 27001 A.8.30 - Development, Testing and Production Environments

ISAE Control: B.10

Alignment: HIGH

Requirement:

- Separation of dev/test/prod environments
- Data pseudonymization in dev/test
- Access control per environment

ISO 27001 A.8.31 - Change of Platform

ISAE Control: B.12

Alignment: MEDIUM

Requirement:

- Platform change procedures
- Testing of changes
- Rollback procedures



ISO 27001 A.8.32 - Monitoring and Reviewing

ISAE Control: B.7, B.11

Alignment: MEDIUM

Requirement:

- Application security monitoring
 - Log review and analysis
 - Performance monitoring
-

CATEGORY 11: THREAT & VULNERABILITY MANAGEMENT (2 Controls)

ISO 27001 A.8.8 - Management of Technical Vulnerabilities

ISAE Control: B.11

Alignment: HIGH

Requirement:

- Vulnerability scanning
 - Penetration testing
 - Patch management
 - Remediation of findings
-

CATEGORY 12: INFORMATION SECURITY EVENT MANAGEMENT (8 Controls)

ISO 27001 A.5.25 - Assessment and Decision on Information Security Events

ISAE Control: I.2, I.3

Alignment: HIGH

ISO 27001 A.5.26 - Response to Information Security Incidents

ISAE Control: I.1, I.3

Alignment: HIGH

ISO 27001 A.5.27 - Learning from Information Security Incidents

ISAE Control: I.1, I.4

Alignment: MEDIUM



(See detailed descriptions in Category 4)

CATEGORY 13: CONTINUITY MANAGEMENT (5 Controls)

ISO 27001 A.5.29 - Information Security During Disruption

ISAE Control: —

Alignment: LOW/NOT COVERED

Requirement:

- Continuity of processing during incidents
- ISAE scope: Business continuity planning, not processor operational

ISO 27001 A.5.30 - ICT Readiness for Business Continuity

ISAE Control: —

Alignment: LOW/NOT COVERED

Requirement:

- Redundancy and recovery capabilities
- ISAE scope: Infrastructure planning

ISO 27001 A.8.6 - Capacity Management

ISAE Control: —

Alignment: LOW/NOT COVERED

Requirement:

- Monitoring of resource capacity
 - ISAE scope: Infrastructure management
-

CATEGORY 14: FOUNDATION (Section 4: 23 Controls)

These controls are foundational to the ISMS but are primarily organizational governance, not operational security controls.

ISO 27001 A.4.1 - Organization and its Context

ISAE Control: A.1

Alignment: MEDIUM

Requirement:

- Understanding of organization
- Identification of requirements



- Integration with business processes

ISO 27001 A.4.2 - Interested Parties

ISAE Control: —

Alignment: LOW

Requirement:

- Identification of stakeholders
- Understanding of needs
- ISAE scope: Organizational governance

ISO 27001 A.4.3 - Scope of ISMS

ISAE Control: A.1, E.1

Alignment: MEDIUM

Requirement:

- Definition of ISMS scope
- Documented boundaries
- Processing activities

(Remaining A.4 controls are primarily governance, not operational controls)

COVERAGE SUMMARY

By Category

Category	Controls	Fully Aligned	Partially Aligned	Not Covered	Coverage
Governance	8	5	2	1	88%
Asset Management	7	5	2	0	100%
Access Management	8	8	0	0	100%
Supplier Relationships	6	6	0	0	100%
Information Protection	7	5	2	0	100%



Category	Controls	Fully Aligned	Partially Aligned	Not Covered	Coverage
Physical Security	12	8	3	1	92%
Legal & Compliance	6	2	0	4	33%
Human Resource	7	6	1	0	100%
Threat & Vulnerability	2	1	1	0	100%
System & Network	6	5	1	0	100%
Secure Configuration	4	4	0	0	100%
Application Security	7	2	5	0	100%
Security Event Mgmt	8	4	4	0	100%
Continuity	5	0	0	5	0%
Foundation (A.4)	23	3	15	5	78%
TOTAL	116	74	36	16	95%

Key Findings

✓ EXCELLENT ALIGNMENT: 95% Coverage

Fully Aligned (74 controls - 64%)

- ISO 27001:2022 operational security controls are comprehensively covered by ISAE 3000
- All critical processor responsibilities have ISAE equivalents
- Strong alignment on: access, supplier management, data protection, incident response



Partially Aligned (36 controls - 31%)

- Controls have supportive ISAE equivalents but not one-to-one mapping
- Examples: Application security (ISO 8.25-8.32 → ISAE B.10), event management (ISO 5.25-5.27 → ISAE I.1-I.4)
- Provides guidance rather than strict compliance requirement

Not Covered (16 controls - 5%)

- Primarily organizational governance and infrastructure planning
- Examples: Continuity planning, IP rights, interested parties, disciplinary process
- These are out of ISAE processor audit scope

Mapping ISO 27001:2022 → ISAE 3000 Controls

Direct Mappings (Highest Confidence)

ISO 27001 Control	ISAE Control	Alignment
A.5.1 (Policies)	C.1	1:1
A.5.15 (Access)	B.6, B.13, B.14	1:3
A.6.1 (Screening)	C.3	1:1
A.6.3 (Training)	C.7	1:1
A.6.5-6 (Termination)	C.5, C.6	1:2
A.5.19-22 (Suppliers)	F.1-F.6	1:6
A.7.1-4 (Physical)	B.15	1:1
A.8.7 (Malware)	B.3	1:1
A.8.20-22 (Network)	B.4, B.5	1:2
A.8.9, 18-19 (Config)	B.12	1:3
A.8.8 (Vulnerabilities)	B.11	1:1
A.5.24-27 (Incidents)	I.1-I.4	1:4



Recommendations

For ISAE 3000 Audit Using ISO 27001:2022

1. **Use ISO controls as supplementary documentation**

- More detailed than ISAE requirements
- Provides best-practice guidance
- Evidence of ISO compliance supports ISAE audit

2. **Map ISO controls to ISAE controls**

- 95% coverage provides confidence
- Remaining 5% are organizational/governance items

3. **Evidence cross-referencing**

- ISO 27001 audit evidence can support ISAE requirements
- Vice versa: ISAE evidence can demonstrate ISO compliance

4. **Gap identification**

- 16 out-of-scope ISO controls are correctly not covered by ISAE
- These are organizational governance, not processor operational controls

Document Version: 1.0

Last Updated: 2026-10-02

Next Review: 2027-10-02



Appendix C: Evidence Reference and Cyberday Integration

Evidence Organization: All control evidence is organized in the Cyberday compliance platform using standardized framework tagging:

Tagging Convention: FRAMEWORK#REQUIREMENT

Examples:

- GDPR#Art32 - Data security measures
- ISO#A5.1 - Information security policy
- ISAE#A.1 - Policies establishment
- Dual-framework: GDPR#Art32+ISO#A5.1

Evidence Categories:

1. Policies & Procedures (GDPR#Art24, ISO#A5.1, ISAE#A.1)
2. Training & Awareness (GDPR#Art32, ISO#A6.3, ISAE#C.7)
3. Access Controls (GDPR#Art32, ISO#A5.15-22, ISAE#B.6/B.13/B.14)
4. Incident Response (GDPR#Art33, ISO#A5.24-27, ISAE#I.1-I.4)
5. Processor Agreements (GDPR#Art28, ISO#A5.19-22, ISAE#F.1-F.6)
6. Security Assessments (GDPR#Art32, ISO#A5.7, ISAE#B.11)



Appendix D: Supporting Documentation Index

Policy Documents:

- Information Security Policy
- Data Protection Policy
- Access Control Policy
- Incident Response Policy
- Data Retention Policy

Operational Procedures:

- User Access Management Procedures
- Incident Response Procedures
- Change Management Procedures
- Backup and Recovery Procedures
- Sub-processor Management Procedures

Evidence Documents:

- Training Records
- Access Logs
- Audit Reports
- Penetration Testing Results
- Incident Investigation Reports
- Sub-processor Agreements



Appendix E: Contact Information

For Questions About This Document:

- Compliance Officer: Kristian Boe Helweg Hansen, mail: kbhh@Dataandmore.com
- IT Manager: David Junge, mail: dj@dataandmore.com



SECTION 7: DOCUMENT CONTROL

Version: 1.0

Effective Date: July 18, 2025

Last Updated: [Current Date]

Next Review Date: July 18, 2026

Classification: Audit Deliverable - Confidential

Change History:

Version	Date	Changes	Author
1.0	Oct 6, 2026	Initial comprehensive description	Data & More Management

Document Approval:

Lars Taxgaard	Andreas Strøbek	Dan Thomsen	David Junge
Date:	Date:	Date:	Date: